CASE STUDY

Water and Wastewater Networks: The Control Systems, the Chemistry and the Attacks on Them

A TeamStarWolf case study. Published 13 November 2026; every source checked as of that date.

Executive summary

Water is a sector the joint incident response guide calls target-rich and resource-poor [19] (**Confirmed**), and the consequence of failure is direct. A treatment plant doses chemicals into what people drink, a lift station keeps sewage out of streets and rivers, and both are often run by a small municipal staff with an integrator on call and a controller that has been in service for a decade or more. This study is for the people who keep those systems running: utility operators and managers, the integrators and contractors who build and support them, state primacy agencies, WaterISAC members, and security teams asked to help a utility that has never had one. It answers six questions in order: how water and wastewater networks are made up, which technologies, protocols and languages run on them, which devices are commonly found there, what the dated record of incidents and attacks shows, which threat actors to be aware of, and how the record maps to MITRE ATT&CK and the defender's controls.

The sector is large and mostly small. CISA counts about 152,000 public drinking water systems and more than 16,000 wastewater systems, serving over 80 percent of the US population with drinking water and about 75 percent with sewerage treatment [1] (**Confirmed**). EPA states that more than 97 percent of public water systems serve 10,000 or fewer people [3] (**Confirmed**). Its operational technology spans intake, treatment, distribution, storage, pumping and monitoring, through SCADA, HMIs, PLCs and RTUs at remote sites [5] (**Confirmed**), connected over fiber, industrial Ethernet, licensed and unlicensed radio, microwave and cellular links [6] (**Confirmed**). Federal cyber obligations are thin: America's Water Infrastructure Act requires community water systems serving more than 3,300 people to assess cyber risk and plan for emergencies, and nothing more specific [17] (**Confirmed**); EPA's March 2023 interpretation of existing law to include cybersecurity assessments at drinking water systems was withdrawn seven months later after legal challenges [4] (**Confirmed**).

The attack record is dominated by low-skill access to internet-exposed controllers and HMIs, not by sophisticated malware. IRGC-affiliated CyberAv3ngers compromised at least 75 Unitronics devices from November 2023, at least 34 of them in the US Water and Wastewater Systems sector [56] (**Confirmed**). Pro-Russia hacktivists reached exposed HMIs through remote desktop software and changed set points and alarms [63]; in January 2024 CARR claimed responsibility for tank overflows in Abernathy and Muleshoe, Texas, which Treasury says lost tens of thousands of gallons [101] (**Confirmed**). In 2026, an Iranian-affiliated actor disabled shutdown and alarm logic on PLCs [109] and unnamed actors changed passwords and IP addresses on Rockwell MicroLogix PLCs at utilities in at least seven states, causing loss of pressure, flooding and boil water notices [112] [113] (**Confirmed**). Underneath sits Volt Typhoon, which held access to a water utility's IT network for about nine months and potentially had access to remote-session profiles for treatment plants and wells [96] (**Confirmed**).

> Evidence grade: architecture, regulation, standards, vendor documentation, device advisories, joint advisories, sanctions and court records and victim filings are **Confirmed** from primaries opened on 12 and 13 November 2026. Press reports and vendor claims that no primary repeats are **Reported** and attributed. One text search of a specification is **Demonstrated**. Statements that are this study's own reasoning are **Inferred**.

Key facts at a glance

Field	Value
Size (US)	About 152,000 public drinking water systems (50,000 community) and more than 16,000 wastewater systems (CISA) [1]; EPA pages give 148,000 and 156,000 [2] [3]; GAO counts nearly 170,000 water systems [4]
Small systems	More than 97% of public water systems serve 10,000 or fewer people [3]
Lead federal agency	EPA, the Sector Risk Management Agency, chairs the Water Government Coordinating Council [1]
Main federal cyber rule	SDWA Section 1433 as amended by AWIA section 2013 (signed 23 Oct 2018): risk and resilience assessment and emergency response plan for community systems serving more than 3,300, reviewed every five years [17]
Compliance found by EPA	Over 70% of systems inspected since September 2023 violated basic Section 1433 requirements [18]
OT found at a water system	SCADA, HMIs, PLCs, RTUs; sensors, valves, pumps, motors, chemical dosing, analyzers [5] [6]
Field protocols named by federal guidance	Modbus, DNP3, OPC UA and MQTT over fiber, industrial Ethernet, radio, microwave and cellular [6] [33]
Controller languages	IEC 61131-3: Ladder Diagram, Function Block Diagram, Structured Text, Sequential Function Chart (edition 4.0, 22 May 2025) [43]
Most-cited device	Unitronics Vision PLC with integrated HMI: CVE-2023-6448, default administrative password, KEV 11 Dec 2023 [54] [55]
Most recent wave	From 27 Jul 2026: MicroLogix 1100 and 1400 PLCs at utilities in at least seven states; boil water notices and manual operations [112] [113]
Actors named by US agencies	CyberAv3ngers (IRGC-CEC), CARR, NoName057(16), Z-Pentest, Sector16 and Volt Typhoon [56] [64] [96] [109]
ATT&CK record bound here	32 ATT&CK for ICS techniques and 21 Enterprise techniques; groups G1027, G0034, G1017; campaigns C0020 and C0031; two Navigator layers (Part 6)

Key findings

- **The sector is target-rich and resource-poor.** The joint incident response guide describes water and wastewater that way [19]; AA21-287A points to municipal resourcing, unsupported operating systems and outdated controller firmware [20] (**Confirmed**).
- **Exposure, not exploitation, is the usual way in.** CISA, EPA and FBI lead their eight Top Cyber Actions with reducing internet exposure and changing default passwords [15] [16]; every US water OT event of 2023 to 2026 in the record whose access path is published went through an internet-reachable controller, HMI or remote-access path [56] [63] [64] [109] [112] (**Inferred** from **Confirmed** advisories).
- **The air gap is a belief, not a control.** EPA says hardware OT has lower cyber risk only if it is never connected, even occasionally, to a computer, a network or remote access [5]; WaterISAC warns of vendor-installed cellular modems no one documented [7], and CISA's July 2026 alert names undocumented cellular modems as a path [113] (**Confirmed**).

- **The protocols can be secured; most deployments are not shown to be.** Modbus defines no authentication in its 2012 application specification [35] (**Demonstrated**), but a TLS-based Modbus Security protocol exists [36] and DNP3's secure variant implements IEC 62351-5 [40] (**Confirmed**); none of the sources opened here measures deployment.
- **Devices outlive their fixes.** NIST puts OT lifetimes at 10 to 15 years or longer and says patches may not be available for unsupported systems [33]; a Unitronics legacy advisory covers "all versions" [73], and CISA added a 2019 cellular-gateway flaw to KEV in December 2025 with advice to discontinue the product [84] (**Confirmed**).
- **Hacktivist claims run ahead of the facts, and the quiet risk runs behind them.** CISA says the pro-Russia groups regularly make false or exaggerated claims [64], while Volt Typhoon's IT-side presence at a water utility drew no claim at all [96] (**Confirmed**).
- **Independent physical safety limits work.** The 2021 dosing change was reversed by an operator, and the advisory recommends engineered limits such as chemical pump size [57]; WaterISAC calls for non-digital cyber-physical safety systems [7] (**Confirmed**).

Top recommendations

1. **Take controllers and HMIs off the internet.** Put any remote path behind an OT DMZ or bastion host with MFA [9] [16]; check exposure with CISA's free scanning, which looks only at internet-accessible systems [28].
2. **Change every default credential and give each person their own login.** EPA inspectors found unchanged defaults, shared logins and former employees' access [18]; CVE-2023-6448 is a default password [72].
3. **Find the modems and vendor paths you did not install.** Inventory cellular modems and integrator connections [7] [113] and require third-party access controls and session monitoring [7].
4. **Keep offline copies of PLC logic and HMI projects.** CyberAv3ngers replaced ladder logic [56]; the 2026 wave modified project files [112]; Top Cyber Actions asks for OT and IT backups [15].
5. **Rehearse manual operation.** Utilities in the record ran manually after Maine 2021, the November 2023 compromise, Arkansas City 2024 and the 2026 wave [20] [71] [102] [113]; EPA's small wastewater case study updated its plan to run without SCADA [24].
6. **Engineer limits the network cannot override.** Size chemical pumps and set pressure and level protections so a manipulated set point cannot reach a harmful value [57] [7].
7. **Use the free help.** EPA's technical assistance and evaluation programs, CISA's advisors and scanning, WaterISAC, AWWA's assessment tool and WARN mutual aid exist for systems with no security staff [8] [13] [19] [29] [32].
8. **Patch by KEV, in planned OT downtime.** Top Cyber Actions ties OT patching to KEV and scheduled downtime [15]; where no patch exists, isolate or replace the device [33] [84].

Scope and method

This study covers US public drinking water and wastewater systems and the operational technology that runs them: source water and intake, treatment, storage, distribution, collection and lift stations, wastewater treatment and discharge, plus the communications, remote access and enterprise software that reach them. It draws on non-US events where a government or CERT has published them (Canada, Denmark, Norway, Israel, Poland). It answers six questions, one per Part, in order, and follows the method in the case studies README: primary sources first, every claim graded, numbers given as the source states them. Every source in the Sources table was opened on 12 or 13 November 2026. Direct quotations are kept short. Tradecraft is described at the level the advisories use (technique names and ids), never as commands, payloads, default credential values, configurations or port lists for specific products, and nothing here describes classified or non-public systems.

Other studies are the home for several events and actors. Industrial Control System Attacks and Advisories, 2024 to 2026 owns the Unitronics wave, the CARR Texas overflows, Arkansas City, Koege, Bremanger, the Polish water claims, AL25-016, AA25-343A, AA26-097A, the July 2026 PLC wave and the CVE-2018-4063 KEV addition [69] (**Confirmed**); the 2016 chronicle carries the Bowman Avenue Dam indictment of 24 March 2016 and the 2021 chronicle carries the 2021 Florida dosing event [69] [125] (**Confirmed**). Iran-Attributed Threat Actors owns CyberAv3ngers and the IRGC-CEC; Russia-Attributed Threat Actors and Sandworm: The Operations in the Public Record own CARR's GRU links and APT44; China-Attributed Threat Actors owns Volt Typhoon; The Ransomware Ecosystem owns ransomware groups; and Stuxnet is the reference for controller-logic sabotage [125] (**Confirmed**). This study summarizes each in a paragraph or a timeline row and links. It adds the water-specific material those studies do not carry: the sector's structure and rules, EPA's own OT definitions and case studies, the asset taxonomy of the 2025 inventory guide, the protocol and language record, the device advisories that list the water sector, and the Maroochy campaign as ATT&CK records it. The operational-technology stack that water shares with power, oil and gas, manufacturing and hospitals is covered in depth by the critical-infrastructure networks study in this series and by the ICS/OT Security Reference; Part 1.8 summarizes it.

The Intelligence Hub feed was used as a starting index; of its 6,359 rows, three match water terms (the VTScada and Unitronics KEV rows and one secondary news row about malware aimed at Israel's water system) [70] (**Demonstrated**). Its rows are data, and each event here is cited to the primary instead.

Grade	Meaning in this study
Confirmed	Stated in a primary opened for this study: a regulator or government agency, a standard or its publisher's page, a sector ISAC or association, a sanctions, court or securities filing, a vendor's own advisory or documentation, a CVE, NVD or KEV record, ATT&CK itself, or the library's data files
Reported	Stated only in a secondary source (press, a podcast newsletter) or in a vendor's own marketing or research claim that no primary repeats; attributed in the text
Demonstrated	Shown by a check run for this study on a published document or data file (a text search of a specification; a count of feed rows)
Inferred	This study's own reasoning from Confirmed facts, labelled as such

What is overstated and what is understated

Overstated. Four claims recur and go further than the record. First, that the 2021 Florida event proves a targeted remote attack on a water plant: the current advisory says the FBI was "not able to confirm that this incident was initiated by a targeted cyber intrusion", that desktop-sharing software may have been used but this was not confirmed, and that insiders can also abuse such software [57] (**Confirmed**). Second, hacktivist persona claims: the 2024 fact sheet says these actors have exaggerated their capabilities and impacts [63], AA25-343A says they "regularly make false or exaggerated claims" and that some HMI "shutdowns" may have been operator responses [64], and Mandiant cannot independently verify CARR's January 2024 posts [100] (**Confirmed**). Third, that "air-gapped" plants are out of reach: EPA says an air-gapped OT system may still be vulnerable and that only hardware never connected, even occasionally, has lower risk [5], and one large utility's air-gapped SCADA runs over a permanent VPN tunnel to the main office [26] (**Confirmed**). Fourth, the blanket line that Modbus and DNP3 "cannot be secured": both have published secure variants (Modbus Security over TLS; DNP3-SL implementing IEC 62351-5) [36] [40] (**Confirmed**); the gap is deployment, which no source opened here measures (**Inferred**). Sector counts also drift: CISA's 152,000, EPA's 148,000 and 156,000 and GAO's nearly 170,000 are all federal figures for overlapping populations [1] [2] [3] [4] (**Confirmed** for each; the reading is **Inferred**).

Understated. How common low-skill tampering is at small systems: the 2024 fact sheet, AA25-343A, the 2026 wave in at least seven states and EPA's over-70-percent finding describe the same default-password, internet-exposure pattern [63] [64] [112] [18] (**Inferred** from **Confirmed** records). Quiet pre-positioning: Volt Typhoon's footholds in US critical infrastructure lasted at least five years in some cases, and at one water utility it reached a server adjacent to OT [96] (**Confirmed**). Incidents with no named actor: the 2026 MicroLogix wave, the American Water intrusion and the Arkansas City incident carry no attribution [112] [104] [102] (**Confirmed** for [112] and [104]; **Reported** for [102]). Systems below the 3,300-person threshold, and all wastewater systems, have no Section 1433 obligation to certify [17] (**Confirmed**), and EPA itself identified gaps for wastewater and small drinking water systems including no cyber risk assessment requirement [4] (**Confirmed**). The cost of a lost controller is also understated: when operators were locked out in 2026, the result was sustained manual operation and boil water notices, not a quick restart [113] (**Confirmed**).

Part 1: how water and wastewater networks are made up

1.1 The systems and who runs them

A public water system, in EPA's definition, serves at least 15 connections or 25 people for at least 60 days a year; it may be publicly or privately owned, and there are three classes: community systems, non-transient non-community systems (schools, factories, hospitals with their own supply) and transient non-community systems [2] (**Confirmed**). CISA counts about 152,000 public drinking water systems, including 50,000 community water systems, and more than 16,000 wastewater treatment systems; over 80 percent of the US population gets potable water from them and about 75 percent has its sewerage treated by them [1] (**Confirmed**). EPA states more than 97 percent of the 156,000 public water systems it counts on its capacity-development page are small systems serving 10,000 or fewer people [3] (**Confirmed**). GAO, counting nearly 170,000 systems, describes them as increasingly automated, with older technology that is hard to secure, workforce skills gaps and a federal regulator that relies on voluntary cooperation [4] (**Confirmed**).

EPA is the Sector Risk Management Agency and chairs the Water Government Coordinating Council; the Water Sector Coordinating Council is self-organized by owners, operators and their associations [1] (**Confirmed**). Supplying water and managing wastewater are National Critical Functions, and firefighting, healthcare, Energy, Health Care and Public Health and Critical Manufacturing depend on the sector [1] (**Confirmed**). WaterISAC, the sector's information-sharing organization, is governed by a nine-member Board of Managers drawn from utilities and associations [12] (**Confirmed**). The joint incident response guide describes governance as a mix of federal and state, local, tribal and territorial authorities, with disparate maturity across a sector it describes as target-rich and resource-poor [19] (**Confirmed**).

1.2 The process: from intake to discharge

EPA defines a water system's OT by the process it runs: source water intake, treatment, distribution, water storage, pumps and monitoring. Its examples include SCADA, building management, fire control and physical access control, and it warns that an "air-gapped" OT system may still be vulnerable [5] (**Confirmed**). The equipment EPA lists as commonly found is SCADA software for local and remote control of sensors, valves, pumps and motors through HMI software, the HMIs themselves, and PLCs and RTUs at remote locations controlling valves, actuators and sensors [5] (**Confirmed**).

The nine-agency OT asset inventory guide of 13 August 2025 gives a conceptual water and wastewater taxonomy in Appendix D, and says plainly that it is not authoritative [6] (**Confirmed**). Its process areas are collection, water treatment, distribution, re-use water, data management and enterprise integration, wastewater treatment, and communications infrastructure [6]. The assets it lists include sewer metering vaults, sewage pump stations, flow meters, tank level and pressure sensors, pH monitoring, process control PLCs and RTUs, chemical dosing, nutrient removal, remote valves, pressure reducing valves, IoT sensors, aeration, biological treatment, solids handling and sludge dewatering [6] (**Confirmed**).

The same guide ranks criticality. High: intake, discharge and high-pressure pumps; clarifiers and grit removal; aeration and biological reactors; emergency shutdown systems; chemical dosing for pH or disinfection; spill containment; SCADA and DCS; OT communications; backup generators and UPS. Medium: online turbidity, chlorine and dissolved oxygen analyzers, RTUs, PLCs, switches and process firewalls. Low: HVAC, lighting, non-critical HMIs and operator workstations [6] (**Confirmed**). The ranking matters because the attacks in Part 4 landed on PLCs (medium tier) and HMIs (which the guide ranks low when non-critical) to reach effects in the high tier (pumps, dosing, tank levels) (**Inferred**).

NIST SP 800-82r3 places SCADA in water distribution and wastewater collection, where assets are dispersed, and distributed control systems (DCS) in water and wastewater treatment, where the process is concentrated at a plant [33] (**Confirmed**).

1.3 The reference model and zones

EPA guidance (EPA 817-B-23-001, March 2023, revised August 2024) defines the Purdue model as a six-layer model for ICS network segmentation [8] (**Confirmed**). WaterISAC uses the Purdue model to illustrate industrial zones, with industrial devices at levels 0 to 3, and names firewalls, ICS-DMZs, VLANs and unidirectional gateways or data diodes as boundary controls [7] (**Confirmed**). EPA's checklist asks utilities to segment OT from IT and deny OT connections by default through a monitored intermediary (a firewall, bastion host, jump box or DMZ), to keep separate IT and OT credentials, and at minimum to require MFA for remote access to OT [8] (**Confirmed**).

Placed on that model, instruments, analyzers, variable-frequency drives, dosing pumps and PLCs or RTUs sit at the field and control levels at plants and remote sites; HMIs, SCADA servers and engineering workstations sit at the supervisory level; cellular telemetry routers bridge remote sites back to the control center; CISA lists several for the water sector and its July 2026 alert names undocumented cellular modems as a path [61] [88] [113] (**Inferred** placement).

1.4 Remote sites and the wide area

Water is a wide-area system: wells, tanks, booster stations, lift stations and metering vaults are spread across a service area. NIST describes SCADA field sites as RTUs and PLCs, linked by standard and proprietary protocols over serial and network links that carry telemetry over telephone line, cable, fiber and radio (broadcast, microwave and satellite), with remote diagnostics often on a separate dial-up modem or WAN [33] (**Confirmed**). The control center polls field devices at set intervals (NIST's examples are 5 and 60 seconds) and sends new set points as required [33] (**Confirmed**). The 2025 inventory guide lists the communications infrastructure as fiber optic, industrial Ethernet, industrial wireless, cellular, licensed and unlicensed radio and microwave backhaul, with OPC UA, MQTT and Modbus named as polling and data software [6] (**Confirmed**).

NIST says critical OT data crossing cellular, wireless, internet or WAN paths should be cryptographically protected [33], and WaterISAC recommends encrypting control traffic over public telecom or private radio networks [7] (**Confirmed**). WaterISAC also warns about undocumented connectivity, giving the example of a cellular maintenance modem installed by a vendor [7] (**Confirmed**); CISA's July 2026 alert reported PLC targeting that included undocumented cellular modems [113] (**Confirmed**).

1.5 Remote access and third parties

Remote access is normal in this sector. WaterISAC lists engineers, administrators, integrators and support vendors among its users, recommends a DMZ with a jump host, MFA, third-party access requirements and session monitoring, and treats external connections as temporary and routed through an ICS-DMZ; secure remote access is SANS ICS Critical Control No. 4 [7] (**Confirmed**). Its Fundamental 11 treats integrators, contractors, IT service providers and managed security providers as trusted third parties that expand the attack surface, cites ATT&CK `T1199` Trusted Relationship, and notes Log4j embedded in Java-based ICS products used in the water sector [7] (**Confirmed**; see Log4Shell for that vulnerability).

The EPA and CISA fact sheet on internet-exposed HMIs says agencies often find exposed water HMIs through public search platforms, that exposure reveals interfaces, distribution maps and event logs, and that utilities may need their system integrators to apply the fixes; it recommends an OT DMZ or bastion host [9] (**Confirmed**). The CISA landing page for the same fact sheet says exposed HMIs let threat actors view contents, make unauthorized changes and potentially disrupt treatment [10] (**Confirmed**). AA21-287A adds that IT and OT integration lets an attacker reach OT after compromising IT, and names internet-exposed RDP as an access path [20] (**Confirmed**). NIST's Technical Note 2283 (initial public draft, 12 June 2024) describes product-agnostic remote access architectures for water: on-premises examples for medium and large systems and for very small and small systems, and a cloud-based architecture [21] (**Confirmed**).

1.6 What three utilities built

EPA's published case studies show what real programs look like at different sizes. A small wastewater system became fully automated when its new plant came online in 2017; it updated its incident response plan so the plant can run in full manual mode without SCADA, and planned VPN remote SCADA access with MFA [24] (**Confirmed**). At a medium drinking water system, the Board declined contractor support, and the manager self-trained and implemented segmentation, site-specific VPNs and VLANs [25] (**Confirmed**). A large combined system runs SCADA air-gapped on a dedicated intranet, with a permanent VPN tunnel to the main office, and plans to move to hosted SCADA with MFA [26] (**Confirmed**). The three show the range the sector spans: from a plan to run without the network, to self-taught segmentation, to an "air gap" with a tunnel through it and a move toward hosted control (**Inferred**).

1.7 The rules, the frameworks and the help

The law. AWIA was signed on 23 October 2018; its section 2013 amended SDWA Section 1433 to require community water systems serving more than 3,300 people to assess risks, including to electronic, computer or automated systems and their security, and to prepare emergency response plans that include cybersecurity, reviewed every five years [17] (**Confirmed**). Certification deadlines for the risk and resilience assessment were 31 March 2020 and 31 March 2025 for systems serving 100,000 or more; 31 December 2020 and 31 December 2025 for 50,000 to 99,999; and 30 June 2021 and 30 June 2026 for 3,301 to 49,999, with the emergency response plan due six months after each. Small community systems, non-community systems and wastewater systems need not certify [17] (**Confirmed**). EPA mandates no specific standard for the assessment and offers VSAT, a small-system checklist, the Water Cybersecurity Assessment Tool and a free Cybersecurity Evaluation Program [17] (**Confirmed**).

Enforcement. EPA's March 2023 interpretation of existing law to include cybersecurity assessments at drinking water systems was withdrawn seven months later after legal challenges [4] (**Confirmed**). EPA's May 2024 enforcement alert (corrected 1 June 2024) says over 70 percent of systems inspected since September 2023 violated basic Section 1433 requirements; inspectors found default passwords unchanged, single logins shared by all staff, and former employees' access not curtailed. EPA has taken more than 100 enforcement actions since 2020 and can use SDWA Section 1431 emergency powers [18] (**Confirmed**). The alert names IRGC-affiliated actors, pro-Russia hacktivists and PRC state-sponsored actors (Volt Typhoon) as targeting water IT and process control systems, including small systems [18] (**Confirmed**). GAO's status record shows EPA published a sector risk assessment and risk management plan in January 2025, identified gaps for wastewater and small drinking water systems including no cyber risk assessment requirement, and planned a VSAT peer review to finish in late 2026 [4] (**Confirmed**).

Frameworks. WaterISAC's 12 Cybersecurity Fundamentals, released in December 2024, replace the 15 Fundamentals of 2019 and map to CISA's Cross-Sector Cybersecurity Performance Goals (CPGs) and the SANS Five ICS Critical Controls, with guidance for small systems [11] (**Confirmed**). AWWA's Cybersecurity Risk Management Guidance and Assessment Tool generate a prioritized control list from a utility's technology applications, with a Small Systems Option for systems serving 10,000 or fewer, aligned to the NIST CSF and AWIA section 2013 and mapped to EPA priority controls; AWWA also publishes J100-21 on risk and resilience management [13] [14] (**Confirmed**). The ICS monitoring considerations issued under the ICS Cybersecurity Initiative (National Security Memorandum of 28 July 2021) cite ISA/IEC 62443, NIST SP 800-82, SP 800-53 and the CIS Critical Security Controls for ICS inventory and monitoring [30] (**Confirmed**). NIST SP 800-82 Rev. 3 was finalized on 28 September 2023, and an initial public draft of Rev. 4 is open for comment until 30

November 2026 [34] (**Confirmed**). The 2024 Water Sector Roadmap (EPA 810-R-24-002, earlier editions 2009, 2013 and 2017) names cybersecurity among six threat categories, citing reliance on process control systems, the industrial internet, cloud services and AI, and keeps a priority on area-wide loss of water and power [22] (**Confirmed**).

Free help. CISA, EPA and FBI's Top Cyber Actions (23 February 2024) are: reduce internet exposure, conduct assessments, change default passwords, inventory OT and IT assets, build incident response plans, back up OT and IT, patch with KEV priority during scheduled OT downtime, and train staff; the fact sheet names AWWA's tools, WaterISAC's Fundamentals and the Malcolm ICS monitoring tool [15] [16] (**Confirmed**). EPA lists free remote Cybersecurity Technical Assistance (not incident response), the Cybersecurity Evaluation Program, CISA Cybersecurity Advisors and vulnerability scanning, the USDA Circuit Rider program for rural systems and NRWA training for systems under 10,000 [8] (**Confirmed**). The evaluation program's checklist derives from CISA's CPGs; results go only to the utility, and the contractor shares anonymized aggregates with EPA [27] (**Confirmed**). CISA's free external vulnerability scanning, endorsed by the WSCC and ASDWA, reviews only internet-accessible systems [28] (**Confirmed**). CISA and EPA jointly maintain the Water and Wastewater Cybersecurity toolkit, which lists the scanning, the Top Actions, EPA's help desk, a no-cost assessment service and funding through state revolving funds and the State and Local Cybersecurity Grant Program [29] (**Confirmed**). EPA's hub pages list Your Utility Cyber Aware (EPA and FBI) and the same funding routes (updated 22 September 2026), and the free technical assistance and evaluation programs (updated 2 November 2026) [31] [32] (**Confirmed**). The incident response guide tells utilities to use vendor PSIRTs, WaterISAC, state WARN mutual aid networks and state fusion centers [19] (**Confirmed**).

1.8 The shared operational-technology stack, in one paragraph

Water runs on the same OT building blocks as power, oil and gas, manufacturing and hospitals: PLCs and RTUs programmed in IEC 61131-3 languages from Windows engineering workstations, HMIs and SCADA servers on Windows, historians and asset-management systems that bridge to IT, industrial protocols such as Modbus and DNP3 that were designed without authentication, and cellular or radio gateways that reach remote sites [33] [43] [35] [38] (**Confirmed** for each element except the protocol point, which is **Demonstrated** for Modbus [35] and **Inferred** for DNP3 from its 2005 primer [38]). The critical-infrastructure networks study in this series is the home for that shared stack and its cross-sector record; the ICS/OT Security Reference and the ICS ATT&CK Technique Atlas cover it as reference material. What sets water apart is scale at the small end (most systems serve 10,000 or fewer people [3]), direct chemical and public-health consequence (dosing, disinfection, boil water notices [57] [113]), and a regulatory floor that stops at 3,300 people and excludes wastewater [17] (**Inferred** from **Confirmed** records).

Part 2: technologies, protocols and languages

2.1 The telemetry protocols

Modbus. The Modbus Application Protocol Specification V1.1b3 (26 April 2012) calls Modbus the serial de facto standard since 1979 and reserves TCP port 502. Its data model has four tables: discrete inputs (single bits, read-only), coils (single bits, read-write), input registers (16-bit, read-only) and holding registers (16-bit, read-write) [35] (**Confirmed**). A case-insensitive text search of the specification finds no occurrence of "secur" or "authent": the application protocol defines no authentication or integrity mechanism [35] (**Demonstrated**). The Modbus Organization's Modbus Security protocol wraps Modbus in TLS for authentication and message integrity, uses X.509v3 certificates for client and server, and runs on port 802; the organization lists the 1996 specification as obsolete [36] (**Confirmed**). In water, that means a pump start, a valve position or a chemical feed rate held in a holding register can be written by anything that can reach the device, unless the secure variant or a filtering boundary stands in front of it (**Inferred**).

DNP3. DNP3 was developed by Harris, Distributed Automation Products, passed to the DNP Users Group in November 1993 and adopted as IEEE Std 1815 in 2010; it was designed for electric utilities and is also used in water and wastewater, transportation and oil and gas [37] (**Confirmed**). The 2005 DNP3 Primer describes it running over serial and IP, used primarily by electric and water companies, reporting values such as reservoir water levels and carrying commands such as start and stop motor and open and close valve; the primer contains no security, authentication or encryption terms [38] (**Confirmed**). IEEE 1815-2012 was approved on 8 June 2012, published on 10 October 2012, superseded the 2010 edition and has been Inactive-Reserved since 30 March 2023 [39] (**Confirmed**). The DNP Users Group's flyer describes DNP3-SL (formerly Secure Authentication v6) as implementing IEC 62351-5, with application-layer authentication and integrity, support for encryption (HMAC and AEAD), authentication of all messages, X.509 certificates, co-existence with SAv5, and an Authorization Management Protocol providing IEC 62351-8 role-based access control over IP and serial networks [40] (**Confirmed**). The group's "Next Gen DNP Security" summary says SAv6 "now also supports encryption"; this study reads that as SAv5 giving authentication without encryption and base DNP3 having neither unless Secure Authentication is deployed [41] (**Inferred**).

OPC UA and MQTT. The 2025 inventory guide lists OPC UA and MQTT alongside Modbus as polling and data software in water [6] (**Confirmed**). MQTT also appears as the command-and-control channel of IOCONTROL, the Linux IoT and OT malware Claroty attributes to CyberAv3ngers [116] (**Reported**, vendor assessment).

Inspection. NIST notes that OT firewall and IDS/IPS vendors parse Modbus, DNP3 and CIP for deep packet inspection [33] (**Confirmed**), and Top Cyber Actions names the open Malcolm tool for ICS monitoring [15] (**Confirmed**).

The library's ICS/OT Security Reference lists Modbus TCP as having no authentication and no encryption and DNP3 as having weak or optional authentication (Secure Authentication v5); it does not yet describe DNP3-SL and IEC 62351-5, Modbus Security on port 802, or the 2025 edition of IEC 61131-3 [68] (**Demonstrated**). See also Network Protocols Security.

2.2 The languages of the controllers

IEC 61131-3. The 2013 edition (3.0, published 20 February 2013, withdrawn 22 May 2025) defined two textual languages, Instruction List and Structured Text, and two graphical ones, Ladder Diagram and Function Block Diagram [42] (**Confirmed**). The 2025 edition (4.0, published 22 May 2025) specifies Structured Text, Ladder Diagram and Function Block Diagram plus Sequential Function Chart elements, adds UTF-8 strings, and lists added, removed or deprecated features in Annex B [43] (**Confirmed**). Its abstract no longer names Instruction List; whether IL is removed or deprecated is set out in Annex B, which was not opened for this study [43] (**Inferred**). The library has no page for the IEC 61131-3 languages [67] (**Demonstrated**).

Vendor engineering tools. Unitronics VisiLogic is all-in-one software for PLC, HMI, drive and servo applications on Vision and Samba controllers, with a Ladder editor, an HMI editor and a Remote Access utility that shows a controller's HMI panel on a PC [44] (**Confirmed**). Siemens STEP 7 (TIA Portal) Professional programs every generation of SIMATIC controller with graphical LAD and FBD editors [45] (**Confirmed**). Ladder logic is what CyberAv3ngers erased and replaced in 2023 [56], and project files are what the 2026 actors extracted and modified [109] [112] (**Confirmed**): the controller's program is itself the target, as it was at Stuxnet (**Inferred**).

Scripting inside SCADA. Inductive Automation's documentation says "Ignition uses Jython 2.7", giving scripts access to the Java standard library [46] (**Confirmed**); see the library's Python and Java pages. There is no library page for Jython [67] (**Demonstrated**).

2.3 HMI and SCADA platforms

The water record names several Windows-based SCADA and HMI platforms. Trihedral says VTScada had reached 1,000 water and wastewater utilities by October 2016 [47] (**Reported**, vendor claim); CISA's VTScada advisories list the Water and Wastewater Systems sector (ICSA-16-159-01, and ICSA-22-300-04 alongside Energy) [83] [48] (**Confirmed**). Other platforms appear in CISA advisories without a water listing: GE iFIX lists "Multiple" sectors [50], AVEVA's InTouch Access Anywhere lists Critical Manufacturing [51], and Ignition advisories list Critical Manufacturing, Energy and IT [53] [85] (**Confirmed**). AVEVA's own InTouch HMI page describes visualization for any industrial process and does not mention water [52] (**Confirmed**). Advisory sector lists record where a vendor or CISA judged the product deployed; they are not a census, so a missing water listing does not mean a product is absent from water plants (**Inferred**).

2.4 Operating systems, remote-access software and embedded stacks

Windows. The 2021 dosing advisory names an end-of-life Windows 7 host as a likely weakness [57] (**Confirmed**). Microsoft ended Windows 7 extended support in January 2020 and extended security updates in January 2023; the editions include Professional and Ultimate for Embedded Systems [58] (**Confirmed**). AA21-287A says water facilities run unsupported operating systems and outdated controller firmware [20] (**Confirmed**). See Windows.

Remote-access software. TeamViewer may have been used in the 2021 event, which the advisory does not confirm, and the advisory recommends TeamViewer hardening [57] (**Confirmed**). CISA's KEV catalog lists CVE-2019-18988, a TeamViewer Desktop remote-login bypass, added 3 November 2021 [60] (**Confirmed**). The pro-Russia hacktivists used VNC and its Remote Frame Buffer protocol to reach HMIs with default or weak passwords and no MFA [63] [64] (**Confirmed**). AA21-287A names internet-exposed RDP [20] (**Confirmed**).

Embedded real-time stacks. CISA's URGENT/11 advisory for the Wind River VxWorks network stack (ICSA-19-211-01) lists Water and Wastewater Systems among its sectors and records stack and heap overflows, integer underflow and memory-buffer weaknesses (CWE-121, CWE-122, CWE-191, CWE-119) [65] (**Confirmed**). Those are the memory-safety classes typical of C network stacks in embedded real-time systems; the advisory does not itself state the implementation language [65] (**Inferred**). See VxWorks, QNX, FreeRTOS, C and C++.

2.5 Enterprise software that reaches operations

EPA warned on 10 February 2025 that the Trimble Cityworks asset-management platform, used widely by municipalities including water and wastewater systems, was involved in cyber incidents, and pointed to fixed releases 15.8.9 (28 January 2025) and 23.10 (29 January 2025) [23] (**Confirmed**). WaterISAC notes Log4j inside Java-based ICS products used in water [7] (**Confirmed**). EPA's guidance lists AI uses at water systems (pump control, planning, water quality monitoring) and names AI malfunction or adversary-fed corrupt data as a risk [8] (**Confirmed**). The library's SQL, SQL Server, XML and JSON pages cover the data layer these systems share with IT.

Part 3: the devices commonly found

3.1 The inventory

Zone (Inferred placement)	Device class	Where in the process	Criticality per the 2025 guide	Sources
Field	Flow meters, tank level and pressure sensors, pH monitoring, online turbidity, chlorine and dissolved oxygen analyzers	Intake, treatment, storage, distribution, collection	Analyzers medium	[6]
Field	Pumps (intake, discharge, high-pressure), blowers, aeration, motors	Plants, wells, booster and lift stations	High	[6] [63]
Field	Chemical dosing (pH, disinfection), nutrient removal	Treatment	High	[6] [57]
Field	Remote valves, pressure reducing valves, actuators	Distribution, collection	Not ranked	[5] [6]
Field	Variable-frequency drives on pumps	Plants and pump stations (**Inferred**)	Not ranked	[44] [91] [92]
Control	PLCs and RTUs, including PLC-HMI combination units	Plants and remote sites	Medium	[5] [6] [56]
Control	Emergency shutdown systems, spill containment	Plants	High	[6]
Supervisory	HMIs, SCADA servers, DCS, engineering and operator workstations	Control rooms, plants	SCADA and DCS high; non-critical HMIs and workstations low	[6] [33]
Communications	Cellular routers and gateways, licensed and unlicensed radio, microwave, fiber, industrial Ethernet switches, process firewalls	Between remote sites and control center	OT communications high; switches and firewalls medium	[6] [61] [90]
Power	Backup generators and their controllers, UPS	Plants and pump stations	High	[6] [94]
Site systems	Building management, fire control, physical access control, HVAC, lighting	Plants and offices	HVAC and lighting low	[5] [6]
Enterprise integration	Asset-management and work-order systems, historians, data management	Office and data center	Not ranked	[6] [23]

The zone column is this study's placement from NIST's architecture and the advisories (**Inferred**); the device classes and criticality are the guide's (**Confirmed**). The 2025 guide's taxonomy is explicitly conceptual [6].

3.2 What the device advisories record

The table lists advisories and CVE records opened for this study. "Water listed" means the advisory names the Water and Wastewater Systems sector.

Device class	Product and advisory	CVE (weakness)	Score	Water listed	KEV	Sources
PLC with HMI	Unitronics Vision and Samba, VisiLogic before 9.9.00, OS before 12.38 (ICSA-23-348-15)	CVE-2023-6448 (CWE-1188 per CISA as CNA; CWE-798 per NVD)	9.8	Yes	11 Dec 2023	[54] [55] [72] [121]
PLC with HMI	Unitronics Vision Legacy 120, 230, 280, 290, 530, all versions (ICSA-24-109-01)	CVE-2024-1480 (CWE-257)	7.5 (v3.1), 8.7 (v4)	Yes	No	[73]
PLC with HMI	Unitronics Vision (INCD disclosures)	CVE-2024-38434 (CWE-676), CVE-2024-38435 (CWE-703)	6.5 each	Not stated	No	[74]
PLC	Unitronics UniStream Unilogic before 1.35.227	CVE-2024-27767 (CWE-287)	10.0	Not stated	No	[76]
PLC	Rockwell MicroLogix 1100 and 1400 embedded web server	CVE-2022-46670 (CWE-79)	7.1	Not stated	No	[77]
PLC	Rockwell Logix controllers including CompactLogix (ICSA-22-090-05)	CVE-2022-1161 (CWE-829)	10.0	Multiple sectors	No	[78]
PLC and engineering software	Rockwell Logix, RSLogix 5000, Studio 5000 Logix Designer (ICSA-21-056-03)	CVE-2021-22681 (CWE-522)	9.8 (ADP)	Not stated	5 Mar 2026	[59] [79]
PLC and drives	Siemens S7-1200 and S7-1500; SINAMICS PERFECT HARMONY GH180 drives made before 13 Aug 2021 (SSA-434534)	CVE-2020-15782 (CWE-119)	8.1 (Siemens), 9.8 (ADP)	Not stated	No	[80] [93]
PLC	Siemens S7-1200 below V4.5.0 and S7-1500 (SSA-568427)	CVE-2022-38465 (CWE-522)	9.3	Not stated	No	[81]
PLC and RTU tooling	Schneider Modicon M580 and M340, SCADAPack RemoteConnect for x70 (SEVD-2021-194-01)	CVE-2021-22779 (CWE-290)	6.5 (ADP)	Not stated	No	[82]
RTU	Ovarro TBox (ICSA-21-054-04)	CVE-2021-22646 (CWE-94), CVE-2021-22648 (CWE-732), CVE-2021-22644 (CWE-321)	8.8, 8.8, 7.5	No (Critical Manufacturing only)	No	[87]
SCADA	Trihedral VTScada, versions after 8 and before 11.2.02 (ICSA-16-159-01)	CVE-2016-4523 (CWE-125), CVE-2016-4532 (CWE-22), CVE-2016-4510 (CWE-592)	7.5, 9.1, 9.1	Yes	CVE-2016-4523: 15 Apr 2022	[83] [49] [84]
SCADA	Trihedral VTScada (ICSA-22-300-04)	CVE-2022-3181 (CWE-20)	Not recorded here	Yes (with Energy)	No	[48]

Device class	Product and advisory	CVE (weakness)	Score	Water listed	KEV	Sources
HMI and SCADA	GE iFIX (ICSA-23-073-03)	CVE-2023-0598 (CWE-94)	Not recorded here	Multiple	No	[50]
Remote HMI access	AVEVA InTouch and Plant SCADA Access Anywhere (ICSA-22-342-02)	CVE-2022-23854 (CWE-23)	Not recorded here	No	No	[51]
SCADA platform	Inductive Automation Ignition	CVE-2022-1704 (CWE-611); CVE-2025-13911 (CWE-250); May 2024 batch, many CWE-502, for example CVE-2023-39475 and CVE-2023-39476	6.4 (v3.1) and 7.3 (v4) for CVE-2025-13911; up to 9.8 in the batch	No	No	[53] [85] [86]
Open-source SCADA	OpenPLC ScadaBR	CVE-2021-26829 (CWE-79), CVE-2021-26828	Not recorded here	Water use not established by the records opened	28 Nov 2025; 3 Dec 2025	[84]
Cellular gateway	Sierra Wireless AirLink ALEOS (ICSA-19-122-03)	CVE-2018-4061 (CWE-78), CVE-2018-4063 (CWE-434), CVE-2018-4062 (CWE-798)	9.1, 9.1, 6.2	Yes	CVE-2018-4063: 12 Dec 2025	[88] [62] [84]
Cellular gateway	Sierra Wireless AirLink ALEOS (ICSA-23-341-06)	CVE-2023-40458 to CVE-2023-40463, including CWE-798; CVE-2023-40458 (CWE-835)	7.5 for CVE-2023-40458	Yes	No	[61] [89]
Cellular router	Teltonika RMS and RUT routers (ICSA-23-131-08)	Eight CVEs, highest CVE-2023-2586 (CWE-287)	9.0	Yes (with Energy and Critical Manufacturing)	No	[90]
Drive	Rockwell PowerFlex 525 (ICSA-19-087-01)	CVE-2018-19282 (CWE-400)	7.5	No (Critical Manufacturing)	No	[91]
Drive	Rockwell PowerFlex 527; PowerFlex 600T	CVE-2024-2425, CVE-2024-2426, CVE-2024-2427; CVE-2024-9124	7.5 each	Not stated	No	[92]
Generator controller	Deep Sea Electronics DSE855 (ZDI-24-671 and NVD)	CVE-2024-5947 (CWE-306); CVE-2024-5948 and CVE-2024-5950 (stack overflow); CVE-2025-29270	6.5; 8.8; 10.0	Water use not established by the records opened	No	[94] [95]
Embedded stack	Wind River VxWorks, URGENT/11 (ICSA-19-211-01)	CWE-121, CWE-122, CWE-191, CWE-119 classes	Not recorded here	Yes	No	[65]
Remote-access software	TeamViewer Desktop	CVE-2019-18988	Not recorded here	Not applicable	3 Nov 2021	[60]
Asset management	Trimble Cityworks (EPA alert)	Fixed in 15.8.9 and 23.10	Not recorded here	EPA alert to water	Not recorded here	[23]

Three readings follow from the table (**Inferred**). The most-cited device in the record, the Unitronics Vision, carries a 9.8 flaw that is a default password, not a memory-corruption bug [72]. Several products central to water telemetry (cellular gateways, VTScada) are listed for the water sector by CISA, while other SCADA platforms' advisories do not list water, so sector lists understate exposure. And KEV dates can trail disclosure by years: CVE-2021-22681 entered KEV five years after disclosure and CVE-2018-4063 more than six years after [79] [84].

Unitronics' own security page for Vision and Samba says VisiLogic 9.9.00 adds built-in security enhancements and recommends firewalls with no LAN-to-WAN exposure, no port forwarding to automation equipment, and MFA; it makes no end-of-life statement [75] (**Confirmed**). AA23-335A states that Unitronics Vision devices are common in water and wastewater and are also used in energy, food and beverage, transportation and healthcare, and that rebranded units may carry other manufacturers' names [56] (**Confirmed**).

3.3 Lifecycle and patch reality

NIST states that OT technology lifetimes are often 10 to 15 years and sometimes longer, and that components can be isolated and remote, so reaching them takes physical effort [33] (**Confirmed**). It adds that OT updates cannot always be applied on time, that a patch can introduce greater production or safety risk, and that many OT systems run operating systems no longer supported, so patches may not exist [33] (**Confirmed**). In the water record that shows up in three ways, plus one adjacent case. Advisories cover "all versions" of legacy controllers [73]. CISA added the 2019 ALEOS flaw to KEV in December 2025 with a note that the product could be end-of-life and should be discontinued [84]. The DSE855 generator controller flaw, from a product class water plants use for backup power but whose water deployment the records opened do not establish, was published as a zero-day with no patch after no substantive vendor response [94]. And the 2024 hacktivist fact sheet found that several compromised HMIs were unsupported legacy foreign-made devices rebranded as US devices [63] (**Confirmed** for each). Siemens' fix for CVE-2022-38465 required firmware V4.5.0, project migration and secure PG/PC and HMI communication [81], which is engineering work, not a patch download (**Inferred**). Mitigations for Logix controllers include recompile and download, the Run keyswitch, change detection and CIP Security [78] (**Confirmed**).

Part 4: cyber incidents and attacks, a dated record

4.1 Timeline

Events whose home is another study are summarized in one line and linked; the detail is there.

Date	Event	Layer reached	Consequence as the primary states it	Home and sources	Grade
Feb to Apr 2000	Maroochy Water Breach, Queensland: an adversary used the local government's wastewater control system and stolen engineering equipment to disrupt pumping stations (ATT&CK `C0020`)	Wastewater control system, pumping stations	About 800,000 litres of raw sewage released into parks, rivers and a hotel	[97]	Confirmed

Date	Event	Layer reached	Consequence as the primary states it	Home and sources	Grade
2013 (indictment 24 Mar 2016)	Bowman Dam SCADA access alleged in a DOJ indictment unsealed 24 Mar 2016	Dam SCADA	See the 2016 chronicle	[69] [125]	Confirmed as allegation (library home)
Mar 2019	Kansas: a former employee used credentials that had not been revoked to reach a facility computer remotely, in an attempt to threaten drinking water safety	Plant computer	Attempt failed	[20]	Confirmed
Sep 2020	New Jersey: possible Makop ransomware	Not stated	Not detailed	[20]	Confirmed
5 Feb 2021	A US drinking water facility whose responders included the Pinellas County Sheriff, USSS and FBI (the advisory does not name it; the 2021 chronicle does): SCADA used to raise sodium hydroxide dosing	SCADA HMI on Windows 7	Operator reversed it; treatment not affected; FBI could not confirm a targeted intrusion	[57]	Confirmed
Mar 2021	Nevada: ransomware reached SCADA and backup systems	SCADA, backups	Not detailed	[20]	Confirmed
Jul 2021	Maine: ZuCaNo ransomware through remote access to a wastewater SCADA computer	Wastewater SCADA	Plant ran manually	[20]	Confirmed
Aug 2021	California: Ghost ransomware on three SCADA servers, present about a month	SCADA servers	Not detailed	[20]	Confirmed
14 Oct 2021	AA21-287A (FBI, CISA, EPA, NSA) on ongoing threats to water	Advisory	Lists the 2019 to 2021 incidents above; says the sector is not targeted more than others	[20]	Confirmed
Oct 2023	CARR claims an intrusion at a European wastewater facility	Claimed	Claim only	[64]	Confirmed (that the claim was made)
22 Nov 2023 to Jan 2024	CyberAv3ngers deface Unitronics Vision PLCs and HMIs (ATT&CK `C0031`, `G1027`): at least 75 devices, at least 34 in US water and wastewater; ladder logic replaced, upload and download disabled	PLC with integrated HMI, reached on its default port with default or no password	Defacement; a municipal water authority went to manual with no known risk to drinking water	ICS attacks study; [56] [71] [99]	Confirmed

Date	Event	Layer reached	Consequence as the primary states it	Home and sources	Grade
11 Dec 2023	CVE-2023-6448 added to KEV; ICSA-23-348-15 on 14 Dec 2023	Advisory	Fix: VisiLogic 9.9.00	[55] [54]	Confirmed
17 to 18 Jan 2024	CARR posts videos claiming HMI manipulation at Polish and US water utilities	HMIs	Mandiant cannot verify the posts; Mandiant notes US officials later acknowledged incidents, and Treasury records the Texas overflows [101]	ICS attacks study; [100] [101]	Confirmed
Jan 2024	Abernathy and Muleshoe, Texas: water storage tanks overflow; CARR claims it	HMIs	Tens of thousands of gallons lost	ICS attacks study; [101]	Confirmed
2 Feb 2024	Treasury sanctions six IRGC Cyber-Electronic Command officials over the Unitronics hacks	Sanctions	No disruption of critical services	[98]	Confirmed
7 Feb 2024	AA24-038A: Volt Typhoon pre-positioning; one confirmed water compromise reached a vCenter server adjacent to OT over about nine months	IT, adjacent to OT	No OT disruption reported	China study; ICS attacks study; [96]	Confirmed
23 Feb 2024	Top Cyber Actions for Securing Water Systems	Guidance	Eight actions	[15] [16]	Confirmed
1 May 2024	Joint fact sheet on pro-Russia hacktivists (activity 2022 to April 2024)	HMIs through VNC	Set points maxed, alarms off, passwords changed; minor tank overflows; most victims reverted to manual	[63]	Confirmed
May 2024	EPA enforcement alert: over 70% of inspected systems out of compliance	Regulation	Enforcement under SDWA 1431 available	[18]	Confirmed
19 Jul 2024	Treasury designates CARR's leader and primary hacker	Sanctions	Names CARR Russian government-aligned	[101]	Confirmed
2024 (attributed about 18 Dec 2025)	Waterworks near Koege, Denmark: water pressure affected, pipes burst; Danish Defence Intelligence Service attributes it to Z-Pentest	Waterworks control	Customers temporarily without water	ICS attacks study; [105]	Reported
22 Sep 2024	Arkansas City, Kansas: treatment facility switches to manual operations	Not stated	Water safe; no service disruption; no actor named	ICS attacks study; [102]	Reported

Date	Event	Layer reached	Consequence as the primary states it	Home and sources	Grade
25 Sep 2024	CISA alert: continued exploitation of internet-accessible OT in water through default credentials and brute force	Advisory	Not detailed	[103]	Confirmed
3 Oct 2024	American Water Works detects unauthorized activity and disconnects systems (8-K signed 7 Oct 2024)	IT	Believes no water or wastewater facility or operation negatively affected; no actor named	[104]	Confirmed
10 Dec 2024	Claroty describes IOCONTROL, Linux IoT and OT malware using MQTT, tied to CyberAv3ngers	Fuel-system sample	Not tied to water by Claroty	[116]	Reported
13 Dec 2024	EPA and CISA fact sheet on internet-exposed HMIs; records 2024 hacktivist manipulation of water HMIs	Guidance	Forced manual operations	[9] [10]	Confirmed
10 Feb 2025	EPA alert on Cityworks incidents	Municipal asset management	Fixed releases named	[23]	Confirmed
7 Apr 2025	Bremanger dam, western Norway: a floodgate opened for about four hours; PST blames Russian or pro-Russian hackers on 13 Aug 2025	Dam control panel	No injuries; Reuters gives about 500 litres per second, BleepingComputer more than 7.2 million litres	ICS attacks study; [106] [107]	Reported
29 Oct 2025	Canadian Centre for Cyber Security AL25-016: hacktivists tamper with a water facility's pressure values	Internet-accessible ICS	Degraded service for the community	[108]	Confirmed
9 Dec 2025	AA25-343A: CARR, NoName057(16), Z-Pentest and Sector16 against water, food and agriculture and energy; DOJ charges a CARR participant the same day	HMIs through VNC	Loss of view, set-point changes, disabled alarms, some physical damage, no injuries	ICS attacks study; [64] [119]	Confirmed
12 Dec 2025	CVE-2018-4063 (Sierra Wireless ALEOS) added to KEV with advice to discontinue	Cellular gateways	Not detailed	[62] [84]	Confirmed
5 Mar 2026	CVE-2021-22681 (Rockwell Logix) added to KEV	PLC engineering key	Not detailed	[59] [79]	Confirmed

Date	Event	Layer reached	Consequence as the primary states it	Home and sources	Grade
Mar 2026 onward (AA26-097A, 7 Apr 2026, updated 22 Jul 2026)	Iranian-affiliated APT against internet-facing PLCs (Rockwell CompactLogix and Micro850; after the update Schneider Modicon M340, Siemens S7-1200 and modems) in water, government and energy	PLCs over their native industrial protocols	Project files extracted and modified, HMI and SCADA displays manipulated, shutdown and alarm logic disabled; disruption and financial loss	ICS attacks study; [109]	Confirmed
Apr 2026	ZionSiphon OT malware aimed at Israeli water treatment and desalination; a broken country check stops it acting	Modbus (DNP3 and S7comm parts are fragments)	Never treats a host as a target	[110] [111]	Reported (Darktrace vendor analysis; Risky Business for the self-delete detail)
26 to 27 Jul 2026	Minnesota: coordinated attack on OT at more than 30 community water systems; some switched to manual	OT	No actor named	[114]	Reported
From 27 Jul 2026	MicroLogix 1100 and 1400 wave: utilities in at least seven states (FBI and EPA PSA, 30 Jul 2026); CISA alert the same day	Internet-facing PLCs, undocumented cellular modems, shared third-party network setups	IP addresses and passwords changed; loss of monitoring and control, loss of pressure, flooding, boil water notices, sustained manual operations	ICS attacks study; [112] [113]	Confirmed

4.2 How the attacks reached the water

Four access patterns cover the record (**Inferred** from the **Confirmed** rows above).

1. **An internet-reachable controller or HMI with a default or weak password.** The Unitronics wave, the hacktivist HMI tampering, AL25-016 and the 2026 MicroLogix wave all fit [56] [63] [108] [112]; CISA's September 2024 alert names default credentials and brute force [103].
2. **Remote-access software and remote desktop.** The 2021 dosing event (desktop sharing, unconfirmed), Maine's ZuCaNo through remote access, the hacktivists' VNC, and Volt Typhoon's VPN and RDP use [57] [20] [64] [96].
3. **Ransomware that started in IT and reached SCADA hosts.** Nevada, Maine and California in 2021 [20], with plants falling back to manual.
4. **Insiders and credentials that outlived employment.** Kansas 2019 [20] and EPA's inspection findings [18].

None of the US events opened here used a novel controller exploit; the 2026 actors did extract and modify project files, which is controller-level work through legitimate engineering functions [109] [112] (**Confirmed** for the actions; the reading is **Inferred**). The consequences were set-point and alarm changes, lockouts,

overflows, pressure loss and boil water notices; no source opened here reports an injury or a confirmed contamination [63] [64] [113] (**Confirmed** for the stated consequences; the absence is **Inferred**).

Part 5: threat actors to be aware of

5.1 The actors and the layer they reached

Actor	Attribution in the record	Layer reached in water	Library home	Sources
CyberAv3ngers (`G1027`)	IRGC-affiliated persona (CISA); IRGC Cyber-Electronic Command officials sanctioned by Treasury; Rewards for Justice offers up to $10 million	Internet-exposed Unitronics PLCs and HMIs (2023 to 2024)	Iran study	[56] [98] [115] [117]
Iranian-affiliated APT actors (AA26-097A)	Assessed Iranian-affiliated; the advisory compares them to earlier CyberAv3ngers activity	Internet-facing PLCs from several vendors and modems (2026)	Iran study	[109]
CARR (Cyber Army of Russia Reborn)	GRU unit 74455 likely supported its creation (AA25-343A); DOJ indictment alleges it was founded, funded and directed by the GRU (allegation; the defendant pleaded not guilty); Treasury calls it Russian government-aligned; Google TAG assesses it is created and controlled by APT44	HMIs through VNC; Texas tank overflows	Russia study, Sandworm study	[64] [119] [101] [100]
NoName057(16)	Created by CISM (AA25-343A); DOJ reward up to $10 million	HMIs (AA25-343A sectors include water)	Russia study	[64] [119]
Z-Pentest	Formed September 2024, no direct state attribution (AA25-343A); Danish intelligence links it to the Russian state for Koege	HMIs; a Danish waterworks	ICS attacks study	[64] [105]
Sector16	Formed January 2025; may have had indirect Russian government support	HMIs	ICS attacks study	[64]
Volt Typhoon (`G1017`)	PRC state-sponsored (CISA, NSA, FBI, high confidence)	Water utility IT up to a server adjacent to OT	China study	[96] [120]
Ransomware operators (Makop, ZuCaNo, Ghost, unnamed)	Criminal	SCADA servers and backups through IT	Ransomware study	[20]
Insiders and former employees	Individuals	Plant computers through retained credentials	Not applicable	[20] [18]
Unnamed actors (2026 MicroLogix wave; Minnesota; American Water; Arkansas City)	No attribution published	PLCs, OT and IT	ICS attacks study	[112] [114] [104] [102]

5.2 The actors in brief

CyberAv3ngers. AA23-335A describes IRGC-affiliated actors using the CyberAv3ngers persona, reportedly connected to Soldiers of Solomon, and notes that some of their claimed attacks on Israel were false [56] (**Confirmed**). On 2 February 2024 Treasury sanctioned six IRGC-CEC officials, including the head of the IRGC-CEC, Hamid Reza Lashgarian, over the Unitronics hacks; the release does not use the CyberAv3ngers name and says the US remediated the incidents with minimal impact [98] (**Confirmed**). Rewards for Justice ties CyberAv3ngers to the IRGC-CEC, dates US Unitronics compromises from at least 22 November 2023 and says the group used IOCONTROL against ICS and SCADA devices [115] (**Confirmed**). ATT&CK records CyberAv3ngers as `G1027`, a "suspected" IRGC-affiliated APT active since at least 2020 (version 1.1, modified 7 October 2026), and the Unitronics Defacement Campaign as `C0031` [117] [99] (**Confirmed**). AA26-097A assesses that a group of Iranian-affiliated APT actors is behind the 2026 PLC activity and notes that the agencies previously reported similar activity by CyberAv3ngers, which it ties to the IRGC-CEC and for which it lists the aliases Hydro Kitten, Storm-0784, APT Iran, Bauxite, Mr. Soul, Soldiers of Solomon, UNC5691 and Shahid Kaveh Group [109] (**Confirmed**); it does not name CyberAv3ngers as the 2026 actor. If the same actors are behind both, the 2026 activity moved from defacement to disabling shutdown and alarm logic (**Inferred**; the advisory does not establish continuity). The detail is in the Iran study.

The pro-Russia hacktivist groups. The May 2024 fact sheet, issued by ten organizations including NCSC-UK and the Canadian Centre for Cyber Security, names no group but describes the pattern: VNC access to HMIs with default or weak passwords, set points pushed to maximum, alarms disabled, administrator passwords changed [63] (**Confirmed**). Treasury designated CARR's leader Yuliya Pankratova and primary hacker Denis Degtyarenko on 19 July 2024 and said CARR's limited sophistication had so far prevented major damage [101] (**Confirmed**). AA25-343A (9 December 2025, revised 18 December 2025, 25 organizations) assesses that GRU unit 74455 likely supported CARR's creation and that CISM created NoName057(16) [64] (**Confirmed**). DOJ announced charges the same day against a Ukrainian national, Victoria Dubranova; the indictment alleges CARR (also known as Z-Pentest) was founded, funded and directed by the GRU and attacked public drinking water systems in several states, and charges include conspiracy to tamper with public water systems; these are allegations, and the defendant pleaded not guilty [119] (**Confirmed** as to the filing). AA25-343A treats Z-Pentest as a separate group formed in September 2024 [64] (**Confirmed**); the two primaries differ on that point, and this study records both. Mandiant's April 2024 APT44 report describes CARR's January 2024 posts and says it cannot independently verify them or their link to APT44; Google's TAG assesses CARR is created and controlled by APT44 [100] (**Confirmed** that Mandiant says so; the TAG assessment is a vendor assessment, **Reported**). ATT&CK lists APT44 as an alias of Sandworm Team, `G0034` [120] (**Confirmed**).

Volt Typhoon. AA24-038A assesses with high confidence that PRC state-sponsored Volt Typhoon pre-positions on IT networks to enable movement to OT, names water and wastewater among the four sectors primarily affected, and says some footholds lasted at least five years [96] (**Confirmed**). At one water entity, over about nine months, the actors used VPN administrator credentials and RDP to reach a file server, a domain controller, an Oracle Management Server and vCenter, exfiltrated OT documentation, tested default OT vendor credentials on domain-joined OT assets, and potentially had access to PuTTY profiles for water treatment plants, water wells and an electrical substation [96] (**Confirmed**). No OT disruption is reported [96]. ATT&CK records the group as `G1017` [120] (**Confirmed**).

Criminals and insiders. AA21-287A's 2019 to 2021 incidents are ransomware and one former employee; the advisory maps `T1566` Phishing, `T1210` Exploitation of Remote Services and ICS `T0827` Loss of Control, and

says the sector is not targeted more than others [20] (**Confirmed**).

ZionSiphon. Darktrace analyzed OT malware aimed at Israeli water treatment and desalination, meant to alter chlorine and reverse-osmosis pressure settings through developed Modbus logic, with DNP3 and S7comm parts only fragments; a broken country check means it never treats a host as a target, and no actor is named [110] (**Reported**, vendor analysis). Risky Business reports that the check makes it delete itself [111] (**Reported**).

5.3 What the claims are worth

Hacktivist personas sell effect. The fact sheet and AA25-343A both warn of exaggeration [63] [64], and Mandiant cannot independently verify CARR's videos [100]; yet Treasury records real overflows in Texas [101] and Canada's AL25-016 records degraded service [108] (**Confirmed**). The working reading is that some claims are false and some are real, and a utility cannot tell which from the post (**Inferred**). The state actors make no claims at all: Volt Typhoon's presence at a water utility is known from a joint government advisory, not from any claim [96], and the 2026 MicroLogix wave still has no published actor [96] [112] (**Confirmed**). Attribution naming also varies: Treasury's IRGC-CEC release, ATT&CK's `G1027` record and AA26-097A's alias list describe overlapping sets [98] [117] [109] (**Confirmed**); the ICS attacks study carries the actor-name crosswalk [125].

Part 6: MITRE mappings and the defender view

This Part binds the verified record to MITRE ATT&CK v20.0 (Enterprise and ICS), CWE, CAPEC and D3FEND. Every technique id below is present in the library's ATT&CK data, which supplies the names and tactics [122] [126] (**Confirmed**). Enterprise techniques link to their generated pages under `mitre/techniques/`; the library generates no pages for ICS techniques, so ICS ids are cited but not linked [67] (**Confirmed**). Mappings come from ATT&CK's own campaign and group pages and the cited joint advisories' technique tables, plus a small number this study maps from a primary's wording, marked **Inferred**.

6.1 Objects

Object	ATT&CK id	Library page	Relationship to this study
Volt Typhoon	`G1017`	/mitre/groups/G1017.md	AA24-038A water compromise [96] [120]
Sandworm Team (alias APT44)	`G0034`	/mitre/groups/G0034.md	Google TAG's assessment that APT44 created and controls CARR; GRU unit 74455 [100] [64] [120]
IOControl	`S9046`	/mitre/software/S9046.md	Rewards for Justice says CyberAv3ngers used it against ICS and SCADA devices [115] [127]
CyberAv3ngers	`G1027`	No library page; ATT&CK G1027	Unitronics wave; AA26-097A [117]
Unitronics Defacement Campaign	`C0031`	No library page; ATT&CK C0031	November 2023 [99]
Maroochy Water Breach	`C0020`	No library page; ATT&CK C0020	February to April 2000 [97]

The library's ICS group-to-technique data maps 17 ICS techniques to `G1027` and lacks `T0814` and `T0828`, which appear on the live ATT&CK page; `C0031` is not in the library's campaign data [118] [99] (**Confirmed**). None of CARR, NoName057(16), Z-Pentest or Sector16 has an ATT&CK group id in the records opened here.

6.2 ATT&CK for ICS techniques (32)

Id	Name	Tactic	Event	Sources
T0813	Denial of Control	Impact	C0020 Maroochy (2000)	[97]
T0814	Denial of Service	Inhibit Response Function	C0031 (2023-11); G1027	[99] [117]
T0815	Denial of View	Impact	C0020	[97]
T0816	Device Restart/Shutdown	Inhibit Response Function	AA25-343A (2025-12-09)	[64]
T0822	External Remote Services	Initial Access	C0020	[97]
T0823	Graphical User Interface	Execution	AA25-343A; 2021 dosing change through the SCADA HMI (**Inferred**)	[64] [57]
T0826	Loss of Availability	Impact	C0031; G1027	[99] [117]
T0827	Loss of Control	Impact	AA21-287A (2021-10-14); G1027; 2026 MicroLogix wave, "loss of monitoring and control" (**Inferred**)	[20] [117] [112]
T0828	Loss of Productivity and Revenue	Impact	C0031; G1027; AA25-343A	[99] [117] [64]
T0829	Loss of View	Impact	C0031; G1027; AA25-343A; 2026 MicroLogix wave (**Inferred**)	[99] [117] [64] [112]
T0831	Manipulation of Control	Impact	AA25-343A	[64]
T0836	Modify Parameter	Impair Process Control	C0020; AA25-343A; 2024 fact sheet set points maxed (**Inferred**); 2021 dosing change (**Inferred**)	[97] [64] [63] [57]
T0838	Modify Alarm Settings	Inhibit Response Function	C0020; G1027	[97] [117]
T0843	Program Download	Lateral Movement	G1027	[117]
T0845	Program Upload	Collection	G1027; AA26-097A project files extracted (**Inferred**)	[117] [109]
T0848	Rogue Master	Initial Access	C0020	[97]
T0859	Valid Accounts	Persistence, Lateral Movement	AA25-343A	[64]
T0860	Wireless Compromise	Initial Access	C0020	[97]
T0864	Transient Cyber Asset	Initial Access	C0020	[97]
T0871	Execution through API	Execution	G1027	[117]
T0878	Alarm Suppression	Inhibit Response Function	C0020; AA25-343A; AA26-097A alarm logic disabled (**Inferred**)	[97] [64] [109]
T0879	Damage to Property	Impact	C0020; G1027	[97] [117]
T0880	Loss of Safety	Impact	G1027	[117]

Id	Name	Tactic	Event	Sources
T0883	Internet Accessible Device	Initial Access	C0031; G1027; AA25-343A; AA26-097A	[99] [117] [64] [109]
T0885	Commonly Used Port	Command and Control	G1027; AA26-097A	[117] [109]
T0886	Remote Services	Initial Access, Lateral Movement	G1027; AA25-343A	[117] [64]
T0889	Modify Program	Persistence	G1027; AA26-097A and the 2026 PSA, project files modified (**Inferred**)	[117] [109] [112]
T0892	Change Credential	Inhibit Response Function	G1027; AA25-343A; 2026 MicroLogix wave passwords changed (**Inferred**)	[117] [64] [112]
T1692.001	Command Message	Evasion, Impair Process Control	C0020; G1027; AA25-343A (listed as revoked `T0855`)	[97] [117] [64] [66]
T1692.002	Reporting Message	Evasion, Impair Process Control	C0020	[97]
T1694.001	Default Credentials	Persistence, Lateral Movement	C0031; G1027; AA25-343A (listed as revoked `T0812`); Volt Typhoon tested default OT vendor credentials (**Inferred**)	[99] [117] [64] [66] [96]
T1695	Block Communications	Inhibit Response Function	G1027	[117]

6.3 ATT&CK Enterprise techniques (21)

Id	Name	Tactic	Event	Sources
T1591	Gather Victim Org Information	Reconnaissance	AA25-343A	[64]
T1595.002	Vulnerability Scanning	Reconnaissance	AA25-343A	[64]
T1583.003	Virtual Private Server	Resource Development	AA25-343A	[64]
T1566	Phishing	Initial Access	AA21-287A	[20]
T1133	External Remote Services	Persistence, Initial Access	Volt Typhoon VPN access (AA24-038A); Maine 2021 remote access (**Inferred**)	[96] [20]
T1199	Trusted Relationship	Initial Access	Cited by WaterISAC Fundamental 11 for integrators and providers; shared third-party network setups in the 2026 wave (**Inferred**)	[7] [112]
T1078	Valid Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	Volt Typhoon VPN administrator credentials; Kansas 2019 unrevoked credentials (**Inferred**)	[96] [20]
T1078.001	Default Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	AA23-335A	[56]
T1110	Brute Force	Credential Access	AA23-335A	[56]
T1110.003	Password Spraying	Credential Access	AA25-343A	[64]
T1021.001	Remote Desktop Protocol	Lateral Movement	Volt Typhoon RDP in the water compromise (**Inferred**)	[96]
T1021.005	VNC	Lateral Movement	AA25-343A	[64]
T1210	Exploitation of Remote Services	Lateral Movement	AA21-287A	[20]
T1219	Remote Access Tools	Command and Control	AA26-097A	[109]
T1041	Exfiltration Over C2 Channel	Exfiltration	AA26-097A	[109]
T1565	Data Manipulation	Impact	AA26-097A	[109]
T1565.001	Stored Data Manipulation	Impact	AA23-335A	[56]
T1531	Account Access Removal	Impact	AA23-335A	[56]
T1499	Endpoint Denial of Service	Impact	AA23-335A	[56]
T1491.001	Internal Defacement	Impact	AA23-335A	[56]
T1486	Data Encrypted for Impact	Impact	Ransomware at Nevada, Maine and California SCADA hosts, 2021 (**Inferred**)	[20]

6.4 Revoked, relabelled and excluded ids

Id or object	What the source says	Treatment	Why	Source
T0812 (AA25-343A)	Default Credentials, pre-v20 id	Read as `T1694.001`	`superseded_by.jsonl` maps it in v20	[64] [66]
T0855 (AA25-343A)	Unauthorized Command Message, pre-v20 id	Read as `T1692.001` Command Message	Same mapping	[64] [66]
T0869, T0846, T0888, T0866, T0819	Present in the library's ICS data	Not in the layer	No water event opened here names them	[122]
ZionSiphon intended effects (Modbus set-point changes)	Designed, never acted	Not in the layer	No observed effect; a broken check stops it	[110]
Volt Typhoon's documentation theft	OT documentation exfiltrated	Not mapped	No ATT&CK id for it is in the record bound here; `T1078`, `T1133` and `T1021.001` are mapped from the advisory's wording	[96]
AA23-335A ICS ids	The advisory lists Enterprise ids only	ICS mappings for the Unitronics wave come from `C0031` and `G1027`	ATT&CK's own objects	[56] [99] [117]

The ICS id scheme and its v20 renames are in the ICS ATT&CK Technique Atlas.

6.5 CWE and CAPEC

The weakness classes below are as CISA, the CVE record or NVD list them; the names match the library's `data/weaknesses/cwe.jsonl` [67] (**Confirmed**).

CWE	Name	Where it appears	Sources
CWE-20	Improper Input Validation	VTScada (2022)	[48]
CWE-22	Improper Limitation of a Pathname to a Restricted Directory	VTScada (2016)	[83]
CWE-23	Relative Path Traversal	AVEVA Access Anywhere	[51]
CWE-78	Improper Neutralization of Special Elements used in an OS Command	Sierra Wireless ALEOS (2019)	[88]
CWE-79	Improper Neutralization of Input During Web Page Generation	MicroLogix 1100 and 1400 web server; ScadaBR (KEV)	[77] [84]
CWE-94	Improper Control of Generation of Code	GE iFIX; Ovarro TBox	[50] [87]
CWE-119	Improper Restriction of Operations within the Bounds of a Memory Buffer	Siemens S7-1200 and S7-1500; VxWorks	[80] [65]
CWE-121, CWE-122, CWE-191	Stack-based Buffer Overflow; Heap-based Buffer Overflow; Integer Underflow (Wrap or Wraparound)	VxWorks URGENT/11	[65]
CWE-125	Out-of-bounds Read	VTScada (KEV)	[83]

CWE	Name	Where it appears	Sources
CWE-250	Execution with Unnecessary Privileges	Ignition (2025)	[85]
CWE-257	Storing Passwords in a Recoverable Format	Unitronics Vision Legacy	[73]
CWE-287	Improper Authentication	UniStream Unilogic; Teltonika	[76] [90]
CWE-290	Authentication Bypass by Spoofing	Schneider Modicon and SCADAPack tooling	[82]
CWE-306	Missing Authentication for Critical Functionality	DSE855 generator controller	[94]
CWE-321	Use of Hard-coded Cryptographic Key	Ovarro TBox	[87]
CWE-400	Uncontrolled Resource Consumption	PowerFlex 525	[91]
CWE-434	Unrestricted Upload of File with Dangerous Type	Sierra Wireless ALEOS (KEV)	[88]
CWE-502	Deserialization of Untrusted Data	Ignition (May 2024 batch)	[86]
CWE-522	Insufficiently Protected Credentials	Rockwell Logix (KEV); Siemens S7-1200 and S7-1500	[79] [81]
CWE-592	DEPRECATED: Authentication Bypass Issues	VTScada CVE-2016-4510 as the 2016 advisory lists it	[83]
CWE-611	Improper Restriction of XML External Entity Reference	Ignition (2022)	[53]
CWE-676	Use of Potentially Dangerous Function	Unitronics Vision	[74]
CWE-703	Improper Check or Handling of Exceptional Conditions	Unitronics Vision	[74]
CWE-732	Incorrect Permission Assignment for Critical Resource	Ovarro TBox	[87]
CWE-798	Use of Hard-coded Credentials	Sierra Wireless ALEOS (2019 and 2023); CVE-2023-6448 per NVD	[88] [61] [121]
CWE-829	Inclusion of Functionality from Untrusted Control Sphere	Rockwell Logix	[78]
CWE-835	Loop with Unreachable Exit Condition	Sierra Wireless ALEOS (2023)	[89]
CWE-1188	Initialization of a Resource with an Insecure Default	CVE-2023-6448 per the CNA	[54] [72]

The CAPEC bindings are this study's mapping from the records' wording, each with a library page [123] (**Inferred**):

CAPEC	Name	Record	Sources
CAPEC-70	Try Common or Default Usernames and Passwords	Unitronics default password; default HMI passwords; Volt Typhoon's default OT vendor credentials	[72] [63] [96]
CAPEC-49	Password Brute Forcing	AA23-335A brute force; CISA's September 2024 alert	[56] [103]

CAPEC	Name	Record	Sources
CAPEC-16	Dictionary-based Password Attack	AA25-343A password spraying against weak HMI passwords	[64]
CAPEC-560	Use of Known Domain Credentials	Volt Typhoon VPN administrator credentials; Kansas 2019 unrevoked credentials	[96] [20]

See the CWE Reference and the CAPEC Reference.

6.6 D3FEND countermeasures

The recommendations are the primaries' own. The library's Change Default Password page records the artifact OT Controller and lists `T0859`, `T1078` and `T1078.001` among the techniques it counters [124] (**Confirmed**); the other pairings are this study's (**Inferred**).

Recommendation in the record	D3FEND countermeasure	Sources
Change default credentials on every OT device	Change Default Password	[15] [18] [56] [124]
MFA for remote access to OT	Multi-factor Authentication	[8] [7] [56]
Strong, unique passwords; no shared logins	Strong Password Policy	[18] [63]
Revoke former employees' access	Credential Revocation	[18] [20]
Remove controllers and HMIs from the internet; deny OT connections by default	Inbound Traffic Filtering, Network Traffic Filtering, Disable Remote Access	[15] [8] [9] [56]
Unidirectional gateways at the boundary	Directional Network Link	[7]
OT and IT asset inventory	Network Node Inventory, Hardware Component Inventory	[15] [6]
Backups of PLC logic and HMI projects	Restore Configuration	[15] [56]
Encrypt control traffic over public or radio networks	Message Encryption	[7] [33]
Authenticated protocols (Modbus Security, DNP3-SL)	Message Authentication, Certificate-based Authentication	[36] [40]
Protocol-aware OT monitoring	Application Protocol Command Analysis, Operational Process Monitoring	[33] [15] [30]
Monitor vendor and remote sessions	Remote Terminal Session Detection	[7]
Patch with KEV priority in planned OT downtime	Software Update	[15]

Independent engineered safety limits (pump sizing, pressure and level protections) have no D3FEND counterpart in the library pages opened here; they are a process-engineering control [57] [7] (**Inferred**). See the D3FEND Reference.

6.7 Navigator layers

- ICS: `navigator/case-studies/water-treatment-networks-ics.json` (open in Navigator), domain `ics-attack`, the 32 techniques of Part 6.2.

- Enterprise: `navigator/library-layers/water-treatment-networks-enterprise.json` (open in Navigator), domain `enterprise-attack`, ATT&CK version 20, the 21 techniques of Part 6.3.

Each technique carries a comment naming the events and their source numbers in this study; scores are 100 where an advisory or ATT&CK object lists the id and 40 where the mapping is this study's Inferred reading. A technique's presence measures that the record names it, not its severity. See the Navigator layers index.

6.8 The defender view, layer by layer

Water layer	What the record shows	Controls the sources name	Sources
Internet edge	Controllers and HMIs found through public search; default ports and passwords; VNC open	Remove from the internet; OT DMZ or bastion host; free CISA scanning	[9] [56] [64] [28]
Remote access and vendors	Desktop-sharing software (2021); VPN and RDP (Volt Typhoon); integrators who must apply fixes	Jump host, MFA, third-party access requirements, session monitoring	[57] [96] [9] [7]
Remote sites and telemetry	Undocumented cellular modems; gateway flaws in KEV; shared third-party network setups	Inventory modems; encrypt telemetry; retire end-of-life gateways	[113] [84] [112] [7]
PLCs and RTUs	Ladder logic replaced; project files modified; passwords and addresses changed; shutdown and alarm logic disabled	Offline logic backups; change defaults; Run keyswitch and change detection where supported	[56] [109] [112] [78]
HMI and SCADA servers	Set points maxed, alarms off; ransomware on SCADA servers; Windows 7	Unique credentials; supported operating systems; backups of servers and projects	[63] [20] [57] [15]
Process safety	Dosing raised (2021); tanks overflowed (2024); pressure lost (2026)	Independent engineered limits; manual operation plans	[57] [101] [112] [7] [24]
IT and enterprise systems	American Water intrusion; Cityworks; Volt Typhoon on vCenter adjacent to OT	Segment IT from OT; separate credentials; patch enterprise systems that reach OT	[104] [23] [96] [8]
People and governance	Shared logins; former employees' access; self-trained managers	Section 1433 assessments; EPA and AWWA tools; WaterISAC Fundamentals	[18] [25] [17] [13] [11]
Response and sharing	Utilities ran manually; boil water notices	WARN mutual aid, WaterISAC, fusion centers, vendor PSIRTs; EPA and CISA help	[19] [113] [29]

Cross-cutting themes

- **Small systems carry the risk; large systems carry the rules.** Most systems serve 10,000 or fewer people [3] and Section 1433 starts at 3,300 and excludes wastewater [17], while CISA says the 2026 PLC targeting reached water entities of all sizes [113] (**Confirmed**); the burden falls hardest on the small systems with no security staff (**Inferred**).
- **The controller program is the target.** From Maroochy's pumping stations to 2023's replaced ladder logic and 2026's modified project files, the OT-targeted attacks change what the controller does rather than

encrypting a file, while the 2021 ransomware cases show IT-style encryption still reaching SCADA hosts [97] [56] [109] [112] [20] (**Inferred**); Stuxnet is the reference case.

- **Default credentials are a design choice made long ago.** CVE-2023-6448 is a default password with a 9.8 score [72]; EPA found defaults unchanged in the field [18]; the 2025 and 2026 advisories show the pattern continuing [64] [112] (**Inferred**).
- **Security exists in the standards and lags in the plant.** Modbus Security, DNP3-SL and IEC 62351 are published [36] [40], while lifetimes of 10 to 15 years and unsupported operating systems set the pace of change [33] (**Inferred**).
- **Manual operation is the real resilience.** Most US events in Part 4 that report an operational outcome end with staff running the plant by hand, and the 2024 fact sheet says most hacktivist victims reverted to manual control [20] [71] [102] [113] [63] (**Inferred**).
- **Claims and attributions move separately from events.** Hacktivist videos arrive before facts; official attributions arrive months later and sometimes disagree on which persona is which [100] [64] [119] [105] (**Inferred**).

Sources

Each source was opened for this study on the date given. Library data files are cited by their GitHub address; the generated pages they feed are linked in the text.

#	Source	URL	Opened	Grade
1	CISA, Water and Wastewater Sector	https://www.cisa.gov/topics/critical-infrastructure-security-and-resilience/critical-infrastructure-sectors/water-and-wastewater-sector	12 and 13 Nov 2026	Confirmed
2	US EPA, Information about Public Water Systems (updated 16 Mar 2026)	https://www.epa.gov/dwreginfo/information-about-public-water-systems	12 and 13 Nov 2026	Confirmed
3	US EPA, Learn about Capacity Development (updated 19 Aug 2026)	https://www.epa.gov/dwcapacity/learn-about-capacity-development	13 Nov 2026	Confirmed
4	US GAO, GAO-24-106744, report on cybersecurity risks to water and wastewater systems, Aug 2024 (recommendation status as shown in 2026)	`https://www.gao.gov/products/gao-24-106744`	13 Nov 2026	Confirmed
5	US EPA, Assessing if a Water or Wastewater System has Operational Technology, Jan 2024 (PDF)	https://www.epa.gov/system/files/documents/2024-03/assessing-if-a-wws-has-ot_508_c.pdf	13 Nov 2026	Confirmed
6	CISA, EPA and partners, Foundations for OT Cybersecurity: Asset Inventory Guidance, 13 Aug 2025 (PDF, Appendix D)	https://www.epa.gov/system/files/documents/2025-09/joint-guide-foundations-for-ot-cybersecurity-asset-inventory-guidance_508c.pdf	13 Nov 2026	Confirmed
7	WaterISAC, 12 Cybersecurity Fundamentals for Water and Wastewater Utilities, Dec 2024 (PDF)	https://www.waterisac.org/wp-content/uploads/2024/12/WaterISAC_12-Fundamentals_FULL-12-High-Res.pdf	13 Nov 2026	Confirmed

#	Source	URL	Opened	Grade
8	US EPA, EPA 817-B-23-001, Guidance on Improving Cybersecurity at Drinking Water and Wastewater Systems, Mar 2023, rev. Aug 2024 (PDF)	https://www.epa.gov/system/files/documents/2024-08/epa-guidance-on-improving-cybersecurity-at-drinking-water-and-wastewater-systems-1.pdf	13 Nov 2026	Confirmed
9	EPA and CISA, Internet-Exposed HMIs Pose Cybersecurity Risks to Water and Wastewater Systems, 13 Dec 2024 (PDF)	https://www.epa.gov/system/files/documents/2024-12/joint-factsheet-epa-cisa-internet-exposed-human-machine-interfaces-508c.pdf	13 Nov 2026	Confirmed
10	CISA, Internet-Exposed HMIs Pose Cybersecurity Risks to Water and Wastewater Systems (landing page)	https://www.cisa.gov/resources-tools/resources/internet-exposed-hmis-pose-cybersecurity-risks-water-and-wastewater-systems	12 Nov 2026	Confirmed
11	WaterISAC, Cybersecurity Fundamentals	https://www.waterisac.org/fundamentals	12 and 13 Nov 2026	Confirmed
12	WaterISAC, About	https://www.waterisac.org/about	13 Nov 2026	Confirmed
13	AWWA, Cybersecurity	https://www.awwa.org/cybersecurity	13 Nov 2026	Confirmed
14	AWWA, Water Sector Cybersecurity Risk Management Guidance	https://www.awwa.org/resource/cybersecurity-guidance/	12 Nov 2026	Confirmed
15	CISA, EPA and FBI, Top Cyber Actions for Securing Water Systems, 23 Feb 2024 (PDF)	https://www.cisa.gov/sites/default/files/2024-03/fact-sheet-top-cyber-actions-for-securing-water-systems.pdf	13 Nov 2026	Confirmed
16	CISA, Top Cyber Actions for Securing Water Systems (landing page)	https://www.cisa.gov/resources-tools/resources/top-cyber-actions-securing-water-systems	12 Nov 2026	Confirmed
17	US EPA, America's Water Infrastructure Act of 2018: Risk Assessments and Emergency Response Plans	https://www.epa.gov/waterresilience/americas-water-infrastructure-act-2018-risk-assessments-and-emergency-response-plans	13 Nov 2026	Confirmed
18	US EPA, Enforcement Alert: Drinking Water Systems to Address Cybersecurity Vulnerabilities, May 2024, corrected 1 Jun 2024	https://www.epa.gov/enforcement/enforcement-alert-drinking-water-systems-address-cybersecurity-vulnerabilities	12 and 13 Nov 2026	Confirmed
19	CISA, FBI and EPA, Water and Wastewater Sector Incident Response Guide, Jan 2024 (PDF)	https://www.cisa.gov/sites/default/files/2024-10/WWS-Sector_Incident-Response-Guide.pdf	13 Nov 2026	Confirmed
20	FBI, CISA, EPA and NSA, AA21-287A, Ongoing Cyber Threats to U.S. Water and Wastewater Systems, 14 Oct 2021	https://www.cisa.gov/news-events/cybersecurity-advisories/aa21-287a	12 and 13 Nov 2026	Confirmed
21	NIST, Technical Note 2283 (initial public draft), OT remote access for water and wastewater, 12 Jun 2024	https://csrc.nist.gov/pubs/tn/2283/ipd	13 Nov 2026	Confirmed
22	WSCC and WGCC, Roadmap to a Secure and Resilient Water and Wastewater Sector, EPA 810-R-24-002, Jan 2024 (PDF)	https://www.epa.gov/system/files/documents/2024-02/water-sector-roadmap-013024-508.pdf	13 Nov 2026	Confirmed

#	Source	URL	Opened	Grade
23	US EPA, Office of Water cybersecurity alert: Cityworks, 10 Feb 2025 (PDF)	https://www.epa.gov/system/files/documents/2025-02/epa-ow-cybersecurity-alert_cityworks_2_10_2025_508c.pdf	13 Nov 2026	Confirmed
24	US EPA, Cybersecurity Program Case Study: Small Wastewater System (PDF)	https://www.epa.gov/system/files/documents/2023-09/cybersecurity-program-case-study-small-wastewater-system_508c.pdf	13 Nov 2026	Confirmed
25	US EPA, Cybersecurity Program Case Study: Medium Drinking Water System (PDF)	https://www.epa.gov/system/files/documents/2023-09/cybersecurity-program-case-study-medium-drinking-water-system_508c.pdf	13 Nov 2026	Confirmed
26	US EPA, Cybersecurity Program Case Study: Large Combined System (PDF)	https://www.epa.gov/system/files/documents/2023-10/231010-large-combined-case-study_508c.pdf	13 Nov 2026	Confirmed
27	US EPA, Cybersecurity Evaluation Program document (PDF)	https://www.epa.gov/system/files/documents/2025-09/64_240117-cybersecurityevaluationprogram_23041-081225_0.pdf	13 Nov 2026	Confirmed
28	CISA, Free Cyber Vulnerability Scanning for Water Utilities, 24 Aug 2023 (PDF)	https://www.cisa.gov/sites/default/files/2023-09/23-05187d%20-%20Water%20Vulnerability%20Scanning%20Fact%20SheetV2_508c.pdf	13 Nov 2026	Confirmed
29	CISA and EPA, Water and Wastewater Cybersecurity toolkit	https://www.cisa.gov/water	12 and 13 Nov 2026	Confirmed
30	US EPA (ICS Cybersecurity Initiative), ICS Monitoring Technology Considerations (PDF)	https://www.epa.gov/system/files/documents/2023-06/ICS-Monitoring-Technology-Considerations-Final-v2_508c.pdf	13 Nov 2026	Confirmed
31	US EPA, EPA Cybersecurity for the Water Sector (updated 22 Sep 2026)	https://www.epa.gov/waterriskassessment/epa-cybersecurity-water-sector	12 and 13 Nov 2026	Confirmed
32	US EPA, Cybersecurity for the Water Sector (updated 2 Nov 2026)	https://www.epa.gov/cyberwater	12 Nov 2026	Confirmed
33	NIST, SP 800-82 Rev. 3, Guide to Operational Technology (OT) Security, Sep 2023 (PDF)	https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-82r3.pdf	12 Nov 2026	Confirmed
34	NIST CSRC, SP 800-82 Rev. 3 publication page	https://csrc.nist.gov/pubs/sp/800/82/r3/final	12 Nov 2026	Confirmed
35	Modbus Organization, Modbus Application Protocol Specification V1.1b3, 26 Apr 2012 (PDF)	https://www.modbus.org/file/secure/modbusprotocolspecification.pdf	12 Nov 2026	Confirmed; text search Demonstrated
36	Modbus Organization, Modbus specifications	https://www.modbus.org/modbus-specifications	12 Nov 2026	Confirmed
37	DNP Users Group, Overview of DNP3 Protocol	https://www.dnp.org/About/Overview-of-DNP3-Protocol	12 Nov 2026	Confirmed
38	DNP Users Group, DNP3 Primer Rev A, 20 Mar 2005 (PDF)	https://www.dnp.org/Portals/0/AboutUs/DNP3%20Primer%20Rev%20A.pdf	12 Nov 2026	Confirmed
39	IEEE Standards Association, IEEE 1815-2012	https://standards.ieee.org/ieee/1815/5414/	12 Nov 2026	Confirmed

#	Source	URL	Opened	Grade
40	DNP Users Group, DNP3-SL flyer	https://www.dnp.org/API/Evotiva-UserFiles/FileActionsServices/DownloadFile?ItemId=5235&ModuleId=9582&TabId=66	12 Nov 2026	Confirmed
41	DNP Users Group, Next Gen DNP Security summary	https://www.dnp.org/LinkClick.aspx?fileticket=U6xKMy8ojYQ%3d&tabid=66&portalid=0&mid=447	12 Nov 2026	Confirmed (reading Inferred)
42	IEC Webstore, IEC 61131-3:2013	https://webstore.iec.ch/en/publication/4552	12 Nov 2026	Confirmed
43	IEC Webstore, IEC 61131-3:2025	https://webstore.iec.ch/en/publication/68533	12 Nov 2026	Confirmed
44	Unitronics, VisiLogic software for programmable controllers	https://www.unitronicsplc.com/software-visilogic-for-programmable-controllers/	12 Nov 2026	Confirmed
45	Siemens, STEP 7 (TIA Portal)	https://www.siemens.com/global/en/products/automation/industry-software/automation-software/tia-portal/software/step7-tia-portal.html	12 Nov 2026	Confirmed
46	Inductive Automation, Ignition 8.1 documentation: Python scripting	https://docs.inductiveautomation.com/docs/8.1/platform/scripting/python-scripting	12 Nov 2026	Confirmed
47	Trihedral, VTScada reaches 1,000 water and wastewater customers, 28 Oct 2016	https://www.vtscada.com/vtscada-reaches-1000-water-wastewater-customers/	12 Nov 2026	Reported (vendor claim)
48	CISA, ICSA-22-300-04, Trihedral VTScada, 27 Oct 2022	https://www.cisa.gov/news-events/ics-advisories/icsa-22-300-04	12 Nov 2026	Confirmed
49	CISA KEV catalog entry, CVE-2016-4523	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?field_cve=CVE-2016-4523	12 Nov 2026	Confirmed
50	CISA, ICSA-23-073-03, GE iFIX	https://www.cisa.gov/news-events/ics-advisories/icsa-23-073-03	12 Nov 2026	Confirmed
51	CISA, ICSA-22-342-02, AVEVA InTouch Access Anywhere and Plant SCADA Access Anywhere, 8 Dec 2022	https://www.cisa.gov/news-events/ics-advisories/icsa-22-342-02	12 Nov 2026	Confirmed
52	AVEVA, InTouch HMI	https://www.aveva.com/en/products/intouch-hmi/	12 Nov 2026	Confirmed
53	CISA, ICSA-22-207-01, Inductive Automation Ignition, 26 Jul 2022	https://www.cisa.gov/news-events/ics-advisories/icsa-22-207-01	12 Nov 2026	Confirmed
54	CISA, ICSA-23-348-15, Unitronics Vision and Samba, 14 Dec 2023	https://www.cisa.gov/news-events/ics-advisories/icsa-23-348-15	12 Nov 2026	Confirmed
55	CISA KEV catalog entry, CVE-2023-6448	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?field_cve=CVE-2023-6448	12 Nov 2026	Confirmed
56	CISA, FBI, NSA, EPA and INCD, AA23-335A, IRGC-Affiliated Cyber Actors Exploit PLCs in Multiple Sectors, 1 Dec 2023, rev. 14 Dec 2023 and 18 Dec 2024	https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-335a	12 and 13 Nov 2026	Confirmed

#	Source	URL	Opened	Grade
57	CISA, AA21-042A, Compromise of U.S. Water Treatment Facility, 11 Feb 2021, rev. 12 Feb 2021	https://www.cisa.gov/news-events/cybersecurity-advisories/aa21-042a	12 and 13 Nov 2026	Confirmed
58	Microsoft Learn, Windows 7 lifecycle	https://learn.microsoft.com/en-us/lifecycle/products/windows-7	12 Nov 2026	Confirmed
59	CISA, ICSA-21-056-03, Rockwell Automation Logix Controllers, 25 Feb 2021	https://www.cisa.gov/news-events/ics-advisories/icsa-21-056-03	12 Nov 2026	Confirmed
60	CISA KEV catalog entry, CVE-2019-18988	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?field_cve=CVE-2019-18988	12 Nov 2026	Confirmed
61	CISA, ICSA-23-341-06, Sierra Wireless AirLink with ALEOS, 7 Dec 2023	https://www.cisa.gov/news-events/ics-advisories/icsa-23-341-06	12 Nov 2026	Confirmed
62	CISA KEV catalog entry, CVE-2018-4063	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?field_cve=CVE-2018-4063	12 Nov 2026	Confirmed
63	CISA, FBI, NSA, EPA, DOE, USDA, FDA, MS-ISAC, CCCS and NCSC-UK, Defending OT Operations Against Ongoing Pro-Russia Hacktivist Activity, 1 May 2024 (PDF)	https://www.cisa.gov/sites/default/files/2024-05/defending-ot-operations-against-ongoing-pro-russia-hacktivist-activity-508c.pdf	12 and 13 Nov 2026	Confirmed
64	CISA and partners, AA25-343A, pro-Russia hacktivists targeting critical infrastructure, 9 Dec 2025, rev. 18 Dec 2025	https://www.cisa.gov/news-events/cybersecurity-advisories/aa25-343a	12 and 13 Nov 2026	Confirmed
65	CISA, ICSA-19-211-01, Wind River VxWorks (URGENT/11), 30 Jul 2019	https://www.cisa.gov/news-events/ics-advisories/icsa-19-211-01	12 Nov 2026	Confirmed
66	TeamStarWolf library data, data/attack/superseded_by.jsonl	https://github.com/TeamStarWolf/TeamStarWolf/blob/main/data/attack/superseded_by.jsonl	12 and 13 Nov 2026	Confirmed
67	TeamStarWolf library repository tree (mitre/, languages/, operating-systems/, data/weaknesses/)	https://github.com/TeamStarWolf/TeamStarWolf	12 and 13 Nov 2026	Confirmed
68	TeamStarWolf library, ICS_OT_SECURITY_REFERENCE.md	https://github.com/TeamStarWolf/TeamStarWolf/blob/main/ICS_OT_SECURITY_REFERENCE.md	12 Nov 2026	Demonstrated
69	TeamStarWolf library, case-studies/ICS_ATTACKS_AND_ADVISORIES_2024_2026.md	https://github.com/TeamStarWolf/TeamStarWolf/blob/main/case-studies/ICS_ATTACKS_AND_ADVISORIES_2024_2026.md	12 and 13 Nov 2026	Confirmed
70	TeamStarWolf Intelligence Hub, feed.json	https://teamstarwolf.github.io/intelligence-hub/data/feed.json	12 Nov 2026	Demonstrated
71	CISA, Exploitation of Unitronics PLCs used in Water and Wastewater Systems, 28 Nov 2023, updated 19 Dec 2023	https://www.cisa.gov/news-events/alerts/2023/11/28/exploitation-unitronics-plcs-used-water-and-wastewater-systems	12 and 13 Nov 2026	Confirmed
72	CVE Program, CVE-2023-6448 record	https://cveawg.mitre.org/api/cve/CVE-2023-6448	12 Nov 2026	Confirmed

#	Source	URL	Opened	Grade
73	CISA, ICSA-24-109-01, Unitronics Vision Legacy Series, 18 Apr 2024	https://www.cisa.gov/news-events/ics-advisories/icsa-24-109-01	12 Nov 2026	Confirmed
74	NVD, CVE API keyword search "Unitronics Vision"	https://services.nvd.nist.gov/rest/json/cves/2.0?keywordSearch=Unitronics%20Vision	12 Nov 2026	Confirmed
75	Unitronics, Cyber security for Vision and Samba	https://www.unitronicsplc.com/cyber_security_vision-samba/	12 Nov 2026	Confirmed
76	CVE Program, CVE-2024-27767 record	https://cveawg.mitre.org/api/cve/CVE-2024-27767	12 Nov 2026	Confirmed
77	CVE Program, CVE-2022-46670 record	https://cveawg.mitre.org/api/cve/CVE-2022-46670	12 Nov 2026	Confirmed
78	CISA, ICSA-22-090-05, Rockwell Automation Logix Controllers, 31 Mar 2022	https://www.cisa.gov/news-events/ics-advisories/icsa-22-090-05	12 Nov 2026	Confirmed
79	CVE Program, CVE-2021-22681 record	https://cveawg.mitre.org/api/cve/CVE-2021-22681	12 Nov 2026	Confirmed
80	Siemens ProductCERT, SSA-434534, SIMATIC S7-1200 and S7-1500 memory protection bypass, 28 May 2021	https://cert-portal.siemens.com/productcert/html/ssa-434534.html	12 Nov 2026	Confirmed
81	Siemens ProductCERT, SSA-568427, S7-1200 and S7-1500 global private key, 11 Oct 2022	https://cert-portal.siemens.com/productcert/html/ssa-568427.html	12 Nov 2026	Confirmed
82	CVE Program, CVE-2021-22779 record	https://cveawg.mitre.org/api/cve/CVE-2021-22779	12 Nov 2026	Confirmed
83	CISA, ICSA-16-159-01, Trihedral VTScada, Jun 2016, rev. 23 Aug 2018	https://www.cisa.gov/news-events/ics-advisories/icsa-16-159-01	12 Nov 2026	Confirmed
84	CISA, Known Exploited Vulnerabilities catalog (JSON feed, catalog 2026.11.10)	https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json	12 Nov 2026	Confirmed
85	CISA, ICSA-25-352-01, Inductive Automation Ignition, 18 Dec 2025	https://www.cisa.gov/news-events/ics-advisories/icsa-25-352-01	12 Nov 2026	Confirmed
86	NVD, CVE API keyword search "Ignition Inductive"	https://services.nvd.nist.gov/rest/json/cves/2.0?keywordSearch=Ignition%20Inductive	12 Nov 2026	Confirmed
87	CISA, ICSA-21-054-04, Ovarro TBox, 23 Feb 2021, rev. 23 Sep 2021	https://www.cisa.gov/news-events/ics-advisories/icsa-21-054-04	12 Nov 2026	Confirmed
88	CISA, ICSA-19-122-03, Sierra Wireless AirLink ALEOS, May 2019, rev. 23 Apr 2020	https://www.cisa.gov/news-events/ics-advisories/icsa-19-122-03	12 Nov 2026	Confirmed
89	CVE Program, CVE-2023-40458 record	https://cveawg.mitre.org/api/cve/CVE-2023-40458	12 Nov 2026	Confirmed
90	CISA, ICSA-23-131-08, Teltonika Remote Management System and RUT routers, 11 May 2023	https://www.cisa.gov/news-events/ics-advisories/icsa-23-131-08	12 Nov 2026	Confirmed

#	Source	URL	Opened	Grade
91	CISA, ICSA-19-087-01, Rockwell Automation PowerFlex 525, 28 Mar 2019	https://www.cisa.gov/news-events/ics-advisories/icsa-19-087-01	12 Nov 2026	Confirmed
92	NVD, CVE API keyword search "PowerFlex"	https://services.nvd.nist.gov/rest/json/cves/2.0?keywordSearch=PowerFlex	12 Nov 2026	Confirmed
93	CVE Program, CVE-2020-15782 record	https://cveawg.mitre.org/api/cve/CVE-2020-15782	12 Nov 2026	Confirmed
94	Zero Day Initiative, ZDI-24-671, Deep Sea Electronics DSE855, 13 Jun 2024	https://www.zerodayinitiative.com/advisories/ZDI-24-671/	12 Nov 2026	Confirmed
95	NVD, CVE API keyword search "Deep Sea Electronics"	https://services.nvd.nist.gov/rest/json/cves/2.0?keywordSearch=Deep%20Sea%20Electronics	12 Nov 2026	Confirmed
96	CISA, NSA, FBI and partners, AA24-038A, PRC State-Sponsored Actors Compromise and Maintain Persistent Access to U.S. Critical Infrastructure, 7 Feb 2024	https://www.cisa.gov/news-events/cybersecurity-advisories/aa24-038a	12 and 13 Nov 2026	Confirmed
97	MITRE ATT&CK, C0020 Maroochy Water Breach	https://attack.mitre.org/campaigns/C0020/	13 Nov 2026	Confirmed
98	US Treasury, jy2072, sanctions on IRGC Cyber-Electronic Command officials, 2 Feb 2024	https://home.treasury.gov/news/press-releases/jy2072	12 and 13 Nov 2026	Confirmed
99	MITRE ATT&CK, C0031 Unitronics Defacement Campaign (v1.0, modified 31 Jul 2026)	https://attack.mitre.org/campaigns/C0031/	12 and 13 Nov 2026	Confirmed
100	Mandiant (Google Cloud), APT44: Unearthing Sandworm, Apr 2024 (PDF)	https://services.google.com/fh/files/misc/apt44-unearthing-sandworm.pdf	12 and 13 Nov 2026	Confirmed (TAG assessment Reported)
101	US Treasury, jy2473, designations of CARR members, 19 Jul 2024	https://home.treasury.gov/news/press-releases/jy2473	12 and 13 Nov 2026	Confirmed
102	SecurityWeek, Kansas water facility switches to manual operations following cyberattack, Sep 2024	https://www.securityweek.com/kansas-water-facility-switches-to-manual-operations-following-cyberattack/	12 and 13 Nov 2026	Reported
103	CISA, Threat Actors Continue to Exploit OT/ICS through Unsophisticated Means, 25 Sep 2024	https://www.cisa.gov/news-events/alerts/2024/09/25/threat-actors-continue-exploit-otics-through-unsophisticated-means	13 Nov 2026	Confirmed
104	American Water Works Company, Form 8-K, signed 7 Oct 2024	`https://www.sec.gov/Archives/edgar/data/1410636/000119312524233300/d869346d8k.htm`	12 and 13 Nov 2026	Confirmed
105	SecurityWeek (AP), Denmark blames Russia for cyberattacks ahead of elections and on water utility, 19 Dec 2025	https://www.securityweek.com/denmark-blames-russia-for-cyberattacks-ahead-of-elections-and-on-water-utility/	13 Nov 2026	Reported
106	The Star (Reuters), Norway spy chief blames Russian hackers for dam sabotage in April, 13 Aug 2025	https://www.thestar.com.my/news/world/2025/08/13/norway-spy-chief-blames-russian-hackers-for-dam-sabotage-in-april	13 Nov 2026	Reported

#	Source	URL	Opened	Grade
107	BleepingComputer, Pro-Russian hackers blamed for water dam sabotage in Norway, 14 Aug 2025	https://www.bleepingcomputer.com/news/security/pro-russian-hackers-blamed-for-water-dam-sabotage-in-norway/	13 Nov 2026	Reported
108	Canadian Centre for Cyber Security, AL25-016, Internet-accessible ICS abused by hacktivists, 29 Oct 2025	https://www.cyber.gc.ca/en/alerts-advisories/al25-016-internet-accessible-industrial-control-systems-ics-abused-hacktivists	13 Nov 2026	Confirmed
109	CISA and partners, AA26-097A, Iranian-affiliated actors disrupting PLCs, 7 Apr 2026, updated 22 Jul 2026	https://www.cisa.gov/news-events/cybersecurity-advisories/aa26-097a	12 and 13 Nov 2026	Confirmed
110	Darktrace, Inside ZionSiphon: Darktrace's analysis of OT malware targeting Israeli water systems, 16 Apr 2026	https://www.darktrace.com/blog/inside-zionsiphon-darktraces-analysis-of-ot-malware-targeting-israeli-water-systems	13 Nov 2026	Reported (vendor analysis)
111	Risky Business, malware tries to sabotage Israel's water system but fails because it is buggy, 20 Apr 2026	https://risky.biz/tries-to-sabotage-israels-water-system-but-fails-because-its-buggy/	13 Nov 2026	Reported
112	FBI and EPA, PSA I-073026-PSA, targeting of internet-facing MicroLogix PLCs at water utilities, 30 Jul 2026 (PDF)	https://www.ic3.gov/PSA/2026/PSA260730.pdf	12 and 13 Nov 2026	Confirmed
113	CISA, CISA urges Water and Wastewater Systems sector to protect OT against activity targeting PLCs, 30 Jul 2026	https://www.cisa.gov/news-events/alerts/2026/07/30/cisa-urges-water-and-wastewater-systems-sector-protect-ot-against-activity-targeting-plcs	12 and 13 Nov 2026	Confirmed
114	BleepingComputer, CISA warns of cyberattacks disrupting US water utilities, 31 Jul 2026 (relaying Minnesota IT Services)	https://www.bleepingcomputer.com/news/security/cisa-warns-of-cyberattacks-disrupting-us-water-utilities/	13 Nov 2026	Reported
115	US Department of State, Rewards for Justice: CyberAv3ngers	https://rewardsforjustice.net/rewards/cyberav3ngers/	12 Nov 2026	Confirmed
116	Claroty Team82, Inside a new OT/IoT cyber weapon: IOCONTROL, 10 Dec 2024	https://claroty.com/team82/research/inside-a-new-ot-iot-cyber-weapon-iocontrol	12 Nov 2026	Reported (vendor assessment)
117	MITRE ATT&CK, G1027 CyberAv3ngers (v1.1, modified 7 Oct 2026)	https://attack.mitre.org/groups/G1027/	12 Nov 2026	Confirmed
118	TeamStarWolf library data, data/attack/ics/group_to_technique.jsonl	https://github.com/TeamStarWolf/TeamStarWolf/blob/main/data/attack/ics/group_to_technique.jsonl	12 and 13 Nov 2026	Confirmed
119	US Department of Justice, Justice Department announces actions to combat two Russian state-sponsored cyber criminal groups, 9 Dec 2025	https://www.justice.gov/opa/pr/justice-department-announces-actions-combat-two-russian-state-sponsored-cyber-criminal	12 Nov 2026	Confirmed
120	TeamStarWolf library data, data/attack/groups.jsonl	https://github.com/TeamStarWolf/TeamStarWolf/blob/main/data/attack/groups.jsonl	12 and 13 Nov 2026	Confirmed
121	NVD, CVE-2023-6448	https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2023-6448	12 Nov 2026	Confirmed
122	TeamStarWolf library data, data/attack/ics/technique_profiles.jsonl	https://github.com/TeamStarWolf/TeamStarWolf/blob/main/data/attack/ics/technique_profiles.jsonl	12 and 13 Nov 2026	Confirmed

#	Source	URL	Opened	Grade
123	TeamStarWolf library, mitre/capec pages (CAPEC-70, CAPEC-49, CAPEC-16, CAPEC-560)	https://github.com/TeamStarWolf/TeamStarWolf/blob/main/mitre/capec/CAPEC-70.md	12 and 13 Nov 2026	Confirmed
124	TeamStarWolf library, mitre/d3fend/change-default-password.md	https://github.com/TeamStarWolf/TeamStarWolf/blob/main/mitre/d3fend/change-default-password.md	12 Nov 2026	Confirmed
125	TeamStarWolf library, case-studies folder	https://github.com/TeamStarWolf/TeamStarWolf/tree/main/case-studies	12 and 13 Nov 2026	Confirmed
126	TeamStarWolf library data, data/attack/technique_profiles.jsonl	https://github.com/TeamStarWolf/TeamStarWolf/blob/main/data/attack/technique_profiles.jsonl	13 Nov 2026	Confirmed
127	TeamStarWolf library data, data/attack/software.jsonl	https://github.com/TeamStarWolf/TeamStarWolf/blob/main/data/attack/software.jsonl	13 Nov 2026	Confirmed

Not opened, so not cited as sources: the Justice Department release on the Bowman Avenue Dam indictment and the District of Kansas release on the 2019 Ellsworth County case (bot interstitial; the 2016 chronicle carries the dam row); the MITRE Maroochy paper and the Queensland court judgment (403); the 2016 Kemuri Water Company account; the EPA Office of Inspector General report of November 2024 on drinking water cybersecurity; CISA's 2015 Water Sector-Specific Plan; the Schneider SEVD-2021-194-01 PDF (the CVE record was used); Annex B of IEC 61131-3:2025; and vendor pages for FactoryTalk View and WinCC.

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- ICS/OT Security Reference and the ICS ATT&CK Technique Atlas
- Network Protocols Security
- Firmware and IoT Security Reference
- Supply Chain Security
- Ransomware Defense Reference
- Threat Actors
- Malware Families
- Notable Incidents

- CVE Reference
- Library discipline, hub, platform, language and operating-system pages: ICS/OT security, Radio-frequency security, ICS/OT and hardware hub, Dragos, Claroty, Windows, VxWorks, QNX, FreeRTOS, C, C++, Python, Java, SQL, SQL Server, XML, JSON
- MITRE pages: groups G1017 Volt Typhoon, G0034 Sandworm Team; software S9046 IOControl; techniques T1078.001, T1110, T1021.005, T1219, T1565, T1491.001 and the rest linked in Part 6.3
- CWE Reference, CAPEC Reference, D3FEND Reference
- Other studies: Industrial Control System Attacks and Advisories, 2024 to 2026, Stuxnet, Sandworm: The Operations in the Public Record, Iran-Attributed Threat Actors, Russia-Attributed Threat Actors, China-Attributed Threat Actors, The Ransomware Ecosystem, Log4Shell, and the chronicles for 2016, 2021, 2023, 2024, 2025 and 2026
- Navigator layers, including this study's layers, water-treatment-networks-ics.json and water-treatment-networks-enterprise.json
- All case studies